Governance von Künstlicher Intelligenz: Eine vergleichende Analyse bestehender Modelle zur Gestaltung unternehmensinterner KI-Steuerung

Seminararbeit
im Studiengang IT-Management
der Universität Münster Professional School

vorgelegt von
Nick Ansgar Stelzer
Email: nick.stelzer@saria.com

Themensteller:	Prof. Dr. Dr. h.c. Becker
Ausgabedatum:	02.07.2025
Abgabedatum:	27.08.2025

Inhaltsverzeichnis

Abkürzungsverzeichnis **II**

Abbildungsverzeichnis **III**

1 Einleitung **1**

2 Grundlagen der AI-Governance **3**
2.1 Künstliche Intelligenz 3
2.2 IT-Governance als konzeptionelle Grundlage 3
2.3 Definition und Verständnis von AI-Governance 4
2.4 Abgrenzung zu verwandten Konzepten 4
2.5 Normative Rahmenwerke 5

3 Vorstellung & Analyse ausgewählter Modelle der AI-Governance **7**
3.1 ISO/IEC 42001 7
3.2 EU AI Act 9
3.3 NIST AI Risk Management Framework 13

4 Vergleich und Bewertung (Matrix) **15**
4.1 Bewertungslogik und Datengrundlage 15
4.2 Kriterienkatalog 15
4.3 Scoring- und Gewichtungsschema 16
4.4 Methodisches Vorgehen: Qualitative Experteninterviews 17
4.5 Sensitivitäts- und Szenarioanalyse 17
4.6 Darstellung der Ergebnisse 17

5 Reflexion **18**

6 Empfehlungen für die Gestaltung von AI-Governance **19**

Literaturverzeichnis **20**

A Appendix **22**
A.1 Einleitung 22

B Appendix **25**

C Abbildungen **40**

Abkürzungsverzeichnis

AI Artifical Intelligence 1

AIMS AI Management System 8

GPAI General-Purpose AI 11

IEC International Electrotechnical Commission 7

ISO International Organization for Standardization 7

KI Künstliche Intelligenz 1

KMU kleine und mittlere Unternehmen 11

NIST National Institute of Standards and Technology 3

Die in dieser Arbeit erwähnten Unternehmens-, Produkt- oder Markenbezeichnungen können Marken oder eingetragene Markenzeichen der jeweiligen Eigentümer sein. Die Wiedergabe von Marken- und/oder Warenzeichen in dieser Arbeit berechtigt nicht zu der Annahme, dass diese als frei von Rechten Dritter zu betrachten seien. Alle erwähnten Marken- und/oder Warenzeichen unterliegen uneingeschränkt den länderspezifischen Schutzbestimmungen und den Besitzrechten der jeweiligen eingetragenen Eigentümer.

Abbildungsverzeichnis

Alle Abbildungen befinden sich ebenfalls im Anhang.

1 Einleitung

Die zunehmende Verbreitung und Leistungsfähigkeit von Anwendungen der künstlichen Intelligenz (KI) stellt Unternehmen vor erhebliche Chancen aber auch neue Herausforderungen. Einerseits eröffnen Künstliche Intelligenz (KI)-Systeme Potenziale zur Automatisierung, Effizienzsteigerung und datenbasierten Entscheidungsfindung.[1] Andererseits sind sie mit Risiken verbunden, die von mangelnder Transparenz („Black-Box"-Problematik) über Verzerrungen in den Daten bis hin zu ethischen und regulatorischen Fragen reichen.[2]

Während sich in den vergangenen Jahren umfangreiche Literatur zu IT-Governance und Data Governance entwickelt hat[3][4], ist das Feld der Artifical Intelligence (AI)-Governance noch vergleichsweise jung und heterogen. Unterschiedliche Modelle und Frameworks konkurrieren um Geltung, wobei bislang ein einheitlicher Ansatz für den organisationalen Umgang mit KI fehlt.[5][6] Besonders für Unternehmen stellt sich die Frage, welche Strukturen, Rollen und Mechanismen geeignet sind, um den sicheren, regelkonformen und zugleich innovationsfördernden Einsatz von KI-Systemen zu gewährleisten.[7]

Vor diesem Hintergrund verfolgt die vorliegende Seminararbeit das Ziel, bestehende Konzepte und Modelle der AI-Governance systematisch aufzuarbeiten und vergleichend zu analysieren. Das Forschungsziel besteht darin, auf Basis dieser Analyse sowie ergänzender Experteninterviews Anforderungen und Gestaltungsoptionen für die unternehmensinterne Steuerung von KI abzuleiten. Damit soll die Arbeit nicht nur einen Beitrag zur theoretischen Fundierung, sondern auch praxisorientierte Empfehlungen zur Ausgestaltung von AI-Governance liefern.

Zur Erreichung dieses Forschungsziels ist die Arbeit wie folgt aufgebaut: Kapitel 2 stellt die begrifflichen und konzeptionellen Grundlagen der AI-Governance dar und grenzt sie von verwandten Konzepten ab. Kapitel 3 führt fünf ausgewählte Modelle der AI-Governance ein und analysiert deren Struktur, Schwerpunkte und Anwendungskontexte. In Kapitel 4 werden die Modelle vergleichend gegenübergestellt und bewertet, auch im Hinblick auf die Ergebnisse von Experteninterviews mit zentralen Unternehmensfunktionen (CIO, IT-Security, Datenschutz). Kapitel 5 reflektiert die gewonnenen Erkenntnisse kritisch, bevor in Kapitel 6 konkrete Empfehlungen für die Gestaltung von AI-Governance im Unternehmenskontext abgeleitet werden. Kapitel 7 schließt mit einem Fazit

[1] Rai, Constantinides und Sarker 2019, S. 4, 7.
[2] Comission 2025, S. 13, 14–17.
[3] Weill und Ross 2004, S. 8–10.
[4] Khatri und Brown 2010, S. 148.
[5] Batool, Zowghi und Bano 2023, S. 2–3.
[6] Mäntymäki u. a. 2025, S. 3–4.
[7] Choung, Seberger und David 2024, S. 2–4.

und einem Ausblick auf weiterführende Forschungs- und Praxisfragen.

2 Grundlagen der AI-Governance

Die Diskussion um die Steuerung und Kontrolle von KI setzt zunächst eine begriffliche und konzeptionelleKlärung voraus. Dieses Kapitel legt die theoretischen Grundlagen, indem es zunächst zentrale Begriffe definiert (Abschnitt 2.1) und anschließend den Zusammenhang zwischen IT-Governance und AI-Governance erläutert (Abschnitt 2.2). Darauf aufbauend werden unterschiedliche Definitionen und Verständnisse von AI-Governance vorgestellt (Abschnitt 2.3), bevor eine Abgrenzung zu verwandten Konzepten wie Data Governance und AI Ethics erfolgt (Abschnitt 2.4). Abschließend werden normative Rahmenwerke skizziert, die für die Entwicklung und Umsetzung von AI-Governance relevant sind (Abschnitt 2.5).

2.1 Künstliche Intelligenz

In der Literatur gibt es unterschiedliche Definitionen für den Begriff Künstliche Intelligenz (KI). Rai, Constantinides und Sarker 2019, S. 3 definieren KI als „die Fähigkeit einer Maschine, kognitive Funktionen auszuführen, die wir mit dem menschlichen Geist verbinden, wie Wahrnehmung, Lernen, Problemlösung und Entscheidungsfindung.“ In ähnlicher Weise definiert das National Institute of Standards and Technology (NIST) in ihrem AI Risk Management Framework KI als ein technisches System, das Ergebnisse wie Vorhersagen, Empfehlungen oder Entscheidungen erzeugen kann, die reale oder virtuelle Umgebungen beeinflussen können.[8]
Diese Defitionen verdeutlichen, dass KI-Systeme nicht nur technische Werkzeuge sind, sondern tiefgreifende Auswirklungen auf gesellschaftliche Prozesse und Strukturen haben können. Daraus ergibt sich die Notwendigkeit einer gezielten Steuerung und Kontrolle, um sicherzustellen, dass sie im Einklang mit ethischen, rechtlichen und sozialen Standards entwickelt und eingesetzt werden.

2.2 IT-Governance als konzeptionelle Grundlage

AI-Governance knüpft an bestehende Governance-Ansätze an und baut insbesondere auf Konzepten der IT-Governance auf. Sie umfasst „die Spezifikation von Entscheidungsrechten und Rechenschaftsmechanismen, um sicherzustellen, dass die Nutzung von IT das Verhalten in Übereinstimmung mit den strategischen Zielen des Unternehmens fördert“.[9]

[8] National Institute of Standards and Technology 2025, S. 1.
[9] Weill und Ross 2004, S. 64.

Während sich IT-Governance auf Themen wie Investitionen, IT-Architektur oder Sicherheitsmanagement konzentriert, erweitert AI-Governance diesen Rahmen um ethische, regulatorische und gesellschaftliche Dimensionen.[10] Sie ist damit als Weiterentwicklung und Spezialisierung der IT-Governance zu verstehen, um den besonderen Herausforderungen und Risiken von KI-Systemen gerecht zu werden.

2.3 Definition und Verständnis von AI-Governance

Eine einheitliche Definition von AI-Governance existiert in der Literatur bislang nicht, es lassen sich jedoch einige zentrale Elemente identifizieren. Mäntymäki u. a. 2025, S. 2–3 definieren AI-Governance als ein System von Regeln, Praktiken, Prozessen und Technologien, die sicherstellt, dass der Einsatz von KI im Einklang mit den Werten und Zielen der Organisation sowie rechtlichen und ethischen Anforderungen steht.
Batool, Zowghi und Bano 2023, S. 2–3 betonen die Betrachtung des kompletten Lebenszyklus von KI-Systemen, von der Entwicklung über den Betrieb bis hin zur Außerbetriebnahme. Zur Analyse schlagen sie das „3W1H“-Schema vor: „Wer ist verantwortlich?, was wird gesteuert?, wann erfolgt die Steuerung? und wie wird diese umgesetzt?“.
Dieser Blickwinkel wir durch Choung, Seberger und David 2024, S. 2–4 erweitert, indem sie AI-Governance als mehrstufiges Konzept verstehen, das auf individueller, organisationaler, nationaler und internationaler Ebene etabliert werden muss, um ein belastbares Vertrauen in KI-Systeme zu ermöglichen.
Damit lässt sich AI-Governance allgemein als ein interdisziplinäres Konzept verstehen, das technische, organisatorische, regulatorische und ethische Dimensionen miteinander verbindet.

2.4 Abgrenzung zu verwandten Konzepten

AI-Governance überschneidet sich mit anderen Disziplinen, unterscheidet sich aber durch ihren umfassenden Anspruch:

- **Data Governance:** Das Ziel der Data Governance ist die Sicherstellung von Datenqualität, -sicherheit und -verfügbarkeit. Khatri und Brown 2010, S. 148–149 definieren Data Governance als „decision righs and accountabilities for setting and enforcing data-related policies“. Damit bildet Data Governance eine notwendige Grundlage für AI-Governance aber diese ist nicht ausreichend um die spezifischen Herausforderungen adaptiver Systeme zu steuern.

[10] Choung, Seberger und David 2024, S. 2–4.

- **AI Ethics:** Ethische Leitlinien, wie etwa die *Ethics Guidelens for Trustworthy AI* der Europäischen Komission, formulieren normative Prinzipien wie Fairness, Transparenz, Rechenschaftspflicht oder Nicht-Diskriminierung.[11] Diese stellen jedoch keinen organisatorischen Umsetzungsrahmen dar.

Während diese Konzepte wichtige Teilaspekte der AI-Governance adressieren, bleibt die konkrete Umsetzung und Integration in bestehende Strukturen oft unklar. Die Zusammenführung der technischen, organisatorischen, ethischen und regulatorischen Dimensionen ist daher eine zentrale Herausforderung der AI-Governance.

2.5 Normative Rahmenwerke

Neben wissenschaftlichen Konzepten und organisationalen Perspektiven spielen normative Rahmenwerke eine zentrale Rolle für die Entwicklung und Umsetzung von AI-Governance. Sie liefern konkrete Leitlinien, Standards und rechtliche Anforderungen, die Unternehmen als Orientierung dienen und gleichzeitig Mindestanforderungen festlegen. Besonders hervorzuheben sind vier zentrale Referenzen

Der **EU AI Act** ist der erste umfassende Rechtsrahmen für Künstliche Intelligenz (KI). Er basiert auf einem risikobasierten Ansatz und unterscheidet zwischen unterschiedlichen Risikoklassen, die von minimalem bis hin zu inakzeptablem Risiko reichen. Für jede Risikoklasse werden spezifische Anforderungen an die Entwicklung, den Einsatz und die Überwachung von KI-Systemen definiert. Insbesondere Hochrisiko-Systeme - etwa im Bereich biometrischer Überwachung oder im Gesundheitswesen - unterliegen strengen Anforderungen an Transparenz, Datenqualität, Dokumentation und menschlicher AUfsicht.[12] Der EU AI Act ist deshalb wichtig, weil er einen verbindlichen rechtlichen Rahmen vorgibt, der Unternehmen dazu zwingt, Governance-Strukturen systematisch zu implementieren.

Die **Ethics Guidelines for Trustworthy AI** definieren „vertrauennswürdige KI“ entlang von sieben Schlüsselprinzipien: menschliche Aufsicht, Robustheit und Sicherheit, Datenschutz und Datenmanagement, Transparenz, Diversität, Nicht-Diskriminierung und Fairness, gesellschaftliches Wohlergehen sowie Rechenschaftspflicht.[13] Sie sind deshalb bedeutsam, weil sie einen normativen Ordnungsrahmen bieten, der über rechtliche Mindestanforderungen hinausgeht und Unternehmen ethische Leitlinien für die verantwortungsvolle Nutzung von KI-Systemen vorgibt.

[11] Comission 2025, S. 14–17.
[12] Kim u. a. 2025, S. 2.
[13] Comission 2025, S. 14–18.

Mit **ISO/IEC 42001:2023** wurde erstmals ein internationaler Standard für ein KI-Managementsystem veröffentlicht. Er beschreibt Anforderungen, wie Organisationen Prozesse zur Steuerung von KI systematisch etablieren, umsetzen und kontinuierliche verbessern können.[14] Dieser Standard ist wichtig, weil er es Unternehmen ermöglicht, AI-Governance in ihre bestehenden Managementsysteme - wie ISO 9001 (Qualitätsmanagement) oder ISO 27001 (Informationssicherheitsmanagement) - zu integrieren und dadurch Governance mess- und auditierbar zu machen.

Das NIST AI Risk Management Framework des US-amerikanischen National Institute of Standards and Technology (NIST) stellt ein freiwilliges Rahmenwerk dar. Es beschreibt vier Kernfunktionen: *Govern, Map, Measure, Manage* und versteht „Govern“ als übergreifende Querschnittsfunktion über den gesamten Lebenszyklus eines KI-Systems.[15] Dieses Framework ist relevant, da Organisationen mit seiner Hilfe ein pragmatisches Instrument nutzen können, um Risiken im Umgang mit KI erkennen zu können und systematisch zu managen, ohne dass dies regulatorisch vorgeschrieben ist.

Zusammenfassend zeigen diese Rahmenwerke, dass AI-Governance nicht im luftleeren Raum entsteht, sondern durch rechtliche Vorgaben, ethische Prinzipien und internationale Standards geprägt wird. Während der EU AI Act verbindliche Mindestanforderungen definiert, geben die Ethics Guidelines normative Orieniterung, die über gesetzliche Anforderungen hinausgeht. ISO/IEC 42001 übersetzt Governance in überprüfbare Managementprozessen und das NIST AI RMF bietet Unternehmen ein praxisnahes Instrument für das Risikomanagement. Gemeinsam bilden diese Rahmenwerke den normativen Kontext, in dem unternehmensinterne Governance-Strukturen ausgestaltet werden müssen. Sie dienen damit zugleich als Referenzpunkt für die Analyse und Bewertung bestehender Modelle, wie sie im folgenden Kapitel vorgestellt werden.

[14] **isoiec42001**.

[15] National Institute of Standards and Technology 2025, S. 21–24.

3 Vorstellung & Analyse ausgewählter Modelle der AI-Governance

Zur theoretischen und praktischen Fundierung der AI-Governance wurden in den vergangenen Jahren unterschiedliche Modelle, Standards und regulatorische Ansätze entwickelt. Sie unterscheiden sich hinsichtlich Ursprung, Zielsetzung und Anwendungsbereich. Für diese Arbeit wurden fünf Modelle ausgewählt, die aufgrund ihrer Relevanz, ihrer unterschiedlichen Schwerpunkte sowie Verbreitung in Wissenschaft, Regulierung und Praxis besonders geeignet erscheinen:

- ISO/IEC 42001 (internationaler Standard für KI-Managementsysteme)[16],
- EU AI Act (europäischer Rechtsrahmen für KI)[17],
- NIST AI Risk Management Framework (US-amerikanisches Rahmenwerk für das Risikomanagement von KI)[18],
- Multilevel AI Governance Framework (mehrstufiges Rahmenwerk für KI-Governance, wissenschaftliches Konzept)[19],
- Hourglass Model of AI Governance (organisatorischer Ansatz)[20].

Die Analyse der Modelle erfolgt nach einheitlichen Kriterien: Zunächst werden Ursprung und Aufbau des Modells vorgestellt. Anschließend werden zentrale Stärken sowie mögliche Schwächen oder Einschränkungen diskutiert. Abschließend wird die Relevanz für die Gestaltung unternehmensinterner AI-Governance bewertet.

3.1 ISO/IEC 42001

Mit der Veröffentlichung von *ISO/IEC 42001:2023* wurde erstmals ein international annerkannter Standard für KI-Managementsysteme etabliert. Der Standard wurde von der International Organization for Standardization (ISO) und der International Electrotechnical Commission (IEC) entwickelt und ist analog zu anderen Managementsystemstandards wie *ISO 9001* (Qualitätsmanagement) und *ISO 27001* (Informationssicherheitsmanagement) aufgebaut, orientiert sich demnach auch an der High-Level-Structure.[21]

[16] ISO 2025.
[17] **europaEUAIAct2021**.
[18] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.
[19] Choung, Seberger und David 2024.
[20] Mäntymäki u. a. 2025.
[21] ISO 2025, S. 1.

3.1.1 Aufbau und zentrale Elemente

Der Standard beschreibt die Anforderungen an ein sogenanntes AI Management System (AIMS), das Organisationen dabei unterstützen soll, den Einsatz von KI-Systemen systematisch zu planen, umzusetzen, zu überwachen und kontinuierlich weiterzuentwickeln. Der Aufbau folgt dem bewährten PLan-Do-Check-Act-Zyklus (PDCA) und umfasst alle wesentlichen Aspekte einer strukturierten Steuerung.
Zu Beginn fordert ISO/IEC 42001 eine Analyse des organisatorischen Kontexts, also der internen und externen Rahmenbedingungen, die den Einsatz von KI beeinflussen. Ebenfalls sollen die Erwartungen der relevanten Interessengruppen (Stakeholder) erfasst werden. Darauf aufbauend wird die Verantwortung des obersten Managements betont, die für die Einführung und Aufrechterhaltung des AIMS verantwortlich ist. Dies umfasst insbesondere die Zuweisung von Rollen und Verantwortlichkeiten sowie die Bereitstellung notwendiger Ressourcen. Ergänzend verlangt der Standard eine systematische Planung, die Risiken und Chancen im Zusammenhang mit KI-Systemen identifiziert, messbare Ziele definiert und geeignete Maßnahmen zur Risiko- und Chancenbewältigung festlegt. Ein weiterer Schwerpunkt liegt auf Supportprozessen wie etwa der Ressourcenbereitstellung, Kompetenzentwicklung, interner Kommunikation sowie Dokumentation und Wissensmanagement. Der operative Teil adressiert den gesamten Lebenszyklus von KI-Systemen, von der Planung über die Implementierung bis hin zur Überwachung und kontinuierlichen Verbesserung. Hierbei werden insbesondere Transparenz, Datenqualität und Nachvollziehbarkeit betont. Hinzu kommen Anforderungen an die Bewertung der Wirksamkeit des Managementsystems durch Monitoring, interne Audits und Managementbewertungen. Abschließend verlangt der Standard die kontinuierliche Verbesserung des AIMS auf Basis der gewonnenen Erkenntnisse im Laufe der Implementierung und Nutzung von KI-Systemen.[22]

3.1.2 Stärken und Schwächen

Eine besondere Stärke von ISO/IEC 42001 liegt in der strukturellen Herangehensweise und die Kompatibilität mit bestehenden ISO-Managementsystemen. Unternehmen die bereits ISO-basierte Managementsysteme etabliert haben, können AI-Governance nahtlos integrieren. Dies erleichtert nicht nur die Implementierung, sondern schafft auch externe Nachvollziehbarkeit durch Zertifizierungen und Auditierungen. Vor allem für global agierende Organisationen bietet der Standard den Vorteil einer international anerkannten Vorgehensweise.

[22] ISO 2025, S. 5–16.

Der Standard weist jedoch auch einige Einschränkungen auf. Seine bewusst allgemeine Formulierung ermöglicht eine flexible Anpassung an unterschiedliche organisatorische Kontexte, birgt jedoch auch das Risiko von Interpretationsspielräumen und uneinheitlicher Umsetzung. Darüber hinaus liegt der Schwerpunkt stark auf organisatorischen Strukturen und Prozessen, während ethische und gesellschaftliche Fragestellungen ebenso wenig Beachtung finden, wie technische Aspekte zur Risikominimierung. Für kleine und mittlere Unternehmen könnte die Umsetzung des Standards eine besondere Herausforderung darstellen, da diese möglicherweise mit erheblichen Ressourcen und Kostenaufwand verbunden ist.

3.1.3 Relevanz für den Unternehmenskontext

Insgesamt bietet ISO/IEC 42001 einen klaren Orientierungsrahmen, um AI-Governance systematisch und nachhaltig zu gestalten. Seine Stärke liegt weniger in detaillierten Vorgaben, sondern vielmehr in der Bereitstellung eines flexiblen Rahmens, der an die spezifischen Bedürfnisse und Gegebenheiten von Unternehmen angepasst werden kann, und in etablierte Managementsysteme integriert werden kann.. Dadurch wird AI-Governance nicht nur professionalisiert, sondern auch international anschlussfähig und prüfbar.

3.2 EU AI Act

Der **EU AI Act** stellt den weltweit ersten umfassenden Rechtsrahmen für den Einsatz von Künstliche Intelligenz (KI) dar. Er wurde von der europäischen Komission vorgeschlagen und 2024 verabschiedet. Ziel des Rechtsakts ist es, einheitliche Standards für die Entwicklung und den Einsatz von Künstliche Intelligenz (KI)-Systemen in der Europäischen Union zu schaffen. Zugleich soll Innovation gefördert und ein hohes Schutzniveau für Bürgerinnen und Bürger sichergestellt werden.[23] Grundlage bildet ein risikobasierter Ansatz, bei dem KI-Systeme nach ihrem Gefährdungspotenzial für Grundrechte und Sicherheit in verschiedene Risikoklassen eingeteilt werden.

3.2.1 Aufbau und zentrale Elemente

Der EU AI Act unterscheidet zwischen vier Risikoklassen:

- **Unakzeptables Risiko:** Diese Systeme sind verboten, da sie gegen grundlegende Rechte und Freiheiten verstoßen (z.B. Social Scoring durch staatliche Stellen).

[23] Kim u. a. 2025, S. 1–3.

- **Hochrisiko:** Hierzu zählen Systeme, die in sicherheitskritischen Bereichen wie Gesundheit, Verkehr oder Justiz eingesetzt werden. Sie unterliegen strengen Anforderungen an Transparenz, Datenqualität und menschliche Aufsicht.
- **Begrenztes Risiko:** Für diese Systeme gelten reduzierte Anforderungen, etwa im Bereich der Nutzerinformation.
- **Minimalrisiko:** Diese Kategorie umfasst Anwendungen mit geringem Risiko, für die keine speziellen Vorgaben bestehen.

Neben dieser Klassifikation legt der EU AI Act umfangreiche Pflichten für Anbieter und Betreiber von KI-Systemen fest. Dazu gehören Risikomanagementprozesse, die Sicherstellung von Datenqualität, die Dokumentation der technischen Infrastruktur, Protokollierungspflichten sowie die Gewährleistung menschlicher Aufsicht. Ergänzend wird ein Konformitätsbewertungsverfahren eingeführt, das je nach Risikoklasse unterschiedliche Anforderungen an die Nachweisführung stellt. Dieses soll sicherstellen, dass die Systeme vor ihrer Markteinführung den gesetzlichen Vorgaben entsprechen. Überwacht wird dies durch nationale Behörden und eine neu geschaffene EU-Behörde für künstliche Intelligenz (EU AI Office).

3.2.2 Stärken und Schwächen

Der EU AI Act überzeugt zunächst durch sienen konsequent risikobasierten Zuschnitt. Er unterscheidet klar zwischen verbotenen Praktiken, Hochrisiko-Systemen, Systemen mit begrenztem Risiko und Minimalrisiko-Anwendungen und verknüpft diese Kategorien mit abgestuften Pflichten. Für Hochrisiko-Systeme werden besonders strenge Anforderungen formuliert, die sicherstellen sollen, dass diese Systeme transparent, nachvollziehbar und unter menschlicher Aufsicht betrieben werden. Das schafft insbesondere in sensiblen Domänen wie Gesundheit und Justiz ein höheres Maß an Rechtssicherheit für Anbieter und Anwender.[24]
Zugleich stärkt der Act den Schutz der Grundrechte, indem er besonders eingriffsintensive Anwendungen ausdrücklich untersagt, darunter Social Scoring, manipulative bzw. täuschende Verfahren, eine weitreichende biometrische Fernidentifikation im öffentlichen Raum (mit Ausnahme von klar definierten Ausnahmen) und Emotionserkennung in Schulen oder der Arbeitswelt.[25] Positiv hervorzuheben ist weiterhin die institutionelle Verankerung: Nationale Marktüberwachungsbehörden, ein EU-weit koordiniertes Vollzugsnetzwerk und die

[24] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.
[25] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.

neu geschaffene EU-Behörde für künstliche Intelligenz (EU AI Office) sollen die einheitliche Anwendung der Vorschriften sicherstellen und den Austausch bewährter Praktiken fördern.[26] Ergänzend adressiert der General-Purpose AI (GPAI) Act die notwendige Dokumentation, Informationsweitergabe an Downstream-Anbieter und urheberrechtskonforme Verfahren. Für Modelle mit „high-impact capabilities“ kommen zusätzliche Pflichten zur Risikoanalyse, Vorfallsberichterstattung und Cybersicherheitsmanagement hinzu.[27]
Ebenfalls soll die Innovationsförderung nicht gehemmt werden, indem sogenannte Regulatory Sandboxes geschaffen werden, in denen Unternehmen neue KI-Anwendungen unter realen Bedingungen testen können, ohne sofort alle regulatorischen Anforderungen erfüllen zu müssen.[28]
Demgegenüber zeigen sich mehrere Schwächen und Umsetzungsrisiken. Erstens kritisiert die Fachliteratur eine mögliche „Cliff-Edge“-Regulierung: Während Hochrisiko-Systeme detailliert reguliert sind, verbleiben zahlreiche Anwendungen im Graubereich mit geringen oder unklaren Anforderungen. In Kombination mit dem sehr weiten Geltungsbereich („alle KI-Systeme“) und der Konzentration der Pflichten auf Hochrisiko-Fälle drohen Regulierungslücken und eine faktische Präemption nationaler Schutzstandards (z.B. zu Transparenz oder Nutzungsbedingungen).[29]
Zweitens ist die starke Anlehung an das Produktsicherheitsrecht widersprüchlich, da die Konkretisierung der Norm über Standardorganisationen erfolgen soll, die traditionell wenig Expertise der Grundrechte haben; zeitgleich wird die Verantwortung für die Einhaltung der Grundrechte auf die Unternehmen abgewälzt. Dies fördert die Einhaltung formaler Standards im Vergleich zu einer eingehenden Prüfung der Grundrechte.[30]
Drittens bleiben die Betroffenenrechte und „bottom-up“ Durchsetzung unzureichend berücksichtigt. Trotz Transparenzinstrumenten wie dem Recht auf Zugang zu Informationen und der Möglichkeit, Beschwerde einzulegen, fehlen klar definierte Beschwerde- und Klagerechte für Betroffene.[31]
Viertens erzeugen die umfangreichen Dokumentations-, Test- und Governance-Pflichten erhebliche Compliance-Lasten, die insbesondere kleine und mittlere Unternehmen (KMU) überproportional belasten können. Gleichzeitig hängt die Wirksamkeit zentraler Schutzmechanismen von einer schnellen und inkusiven Standardisierung ab. In der Debatte wird zudem kritisiert, dass einzelne techni-

[26] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.
[27] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.
[28] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.
[29] **vealeDemystifyingDraftEU2021**.
[30] **vealeDemystifyingDraftEU2021**.
[31] **vealeDemystifyingDraftEU2021**.

sche Schwellen zu hoch angesetzt sein könnten.[32]
Fünftens sind Anforderungen an die menschliche Aufsicht zwar vorgesehen, adressieren in der Praxis jedoch vor allem die Hersteller; robuste, durchsetzbare organisatorische Aufsichts- und Kompetenzpflichten auf Anwenderseite bleiben teilweise nur angedeutet, was Verantwortungslosigkeit und Intransparenz begünstigen könnte.[33]
In der Summme ist der EU AI Act ein globaler Referenzrahmen, der risikoadäquate Pflichten, explizite Verbote, GPAI-Regeln und eine mehrstufige Governance-Architektur vereint. Das Schutzniveau wird in der Praxis jedoch wesentlich von der Qualität und Inklusivität der nachgelagerten Harmonisierungs- und Standardisierungsprozesse, sowie den Aufsichtsmechanismen abhängen.[34][35]

3.2.3 Relevanz für den Unternehmenskontext

Für Unternehmen erzwingt der EU AI Act erstens eine Bestandsaufnahme und Risikoklassifizierung aller KI-Anwendungen; für Hochrisiko-Systeme gelten verbindliche Pflichten (Risikomanagement, Datenqualität, Robustheit, Transparenz, menschliche Aufsicht) samt Konformitätsbewertung vor ihrem Einsatz.[36]
Zudem hat der Act Einfluss auf die Lieferketten, insbesondere bei GPAI-Systemen sind technische Dokumentation, eine Informationsweitergabe an relevante Akteure, insbesondere Kunden und Downstream-Anbieter, sowie eine Kennzeichnung synthetischer Inhalte erforderlich.[37] Weiterhin müssen in Unternehmen die Rollen und die Haftung eindeutig geregelt werden: Wer ein System „off-label“ sprich außerhalb des vorgesehenen Anwendungsbereichs nutzt oder wesentlich ändert, kann rechtlich selber zum Provider werden. Dies bedeutet tiefergreifenden Anforderungen an die interne Governance, insbesondere an die Dokumentation, das Risikomanagement und die Überwachung.[38] Letzendlich sind die Anstrengungen zur Einhaltung (insbesondere für KMUs) zwar kurzfristig höher, aber im Gegenzug stehen klare rechtliche Bestimmungen und Wettbewerbsvorteile bei nachweislicher Übereinstimmung; die Wirksamkeit in der Praxis hängt von einer schnellen, umfassenden Standardisierung und der Kohärenz mit sektorspezifischem Recht ab.[39]

---

[32] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.
[33] **vealeDemystifyingDraftEU2021**.
[34] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.
[35] **vealeDemystifyingDraftEU2021**.
[36] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.
[37] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.
[38] **vealeDemystifyingDraftEU2021**.
[39] **europeanparliamentaryresearchserviceArtificialIntelligenceAct2024**.

3.3 NIST AI Risk Management Framework

Das NIST AI RMF ist ein freiwilliger, sektorneutraler Rahmen zur Steuerung von KI-Risiken über den gesamten Lebenszyklus. Es adressiert alle beteiligten Akteure, liefert gemeinsame Begriffe und Aktivitäten zur Förderung vertrauenswürdiger KI und wird durch ein laufend aktualisiertes Playbook ergänzt. NIST positioniert das RMF ausdrücklich als „living document“, das kontinuierlich weiterentwickelt wird, um den dynamischen Herausforderungen der KI-Technologie gerecht zu werden.[40] Zudem macht NIST die Andersartigkeit von KI-Risiken im Vergleich zu klassischer Software deutlich und hebt die Notwendigkeit hervor, spezifische Ansätze zur Risikominderung zu entwickeln.

3.3.1 Aufbau und zentrale Elemente

Zielbild sind sieben Eigenschaften vertrauenswürdiger KI (*Sicherheit, Sicherheit und Resilienz, Erklärbarkeit und Nachvollziehbarkeit, Datenschutz, Fairness, Transparenz und Zuverlässigkeit*), die als Leitlinien für die Entwicklung und den Einsatz von KI-Systemen dienen.[41] Der sogenannte AI RMF Core umfasst vier Kernfunktionen mit Subkategorien: GOVERN, welches die Rahmenbedingungen für die Anwendungen definiert, bei denen Rollen, Richtlinien und Verantwortlichkeiten im Zusammenspiel mit der Organisationskultur berücksichtigt werden; MAP, das die Identifizierung und Bewertung von Risiken unterstützt, indem Kontext, Anwendungsfälle, Stakeholder und potenzielle Auswirkungen berücksichtigt werden; MEASURE, bei dem die Messung und Bewertung der Leistung von KI-Systemen im Vordergrund steht; und MONITOR, welches die kontinuierliche Überwachung und Verbesserung von KI-Systemen sicherstellt.[42] Weitergehend existieren AI RM Profile, die spezifische Anforderungen und Maßnahmen für verschiedene Anwendungsbereiche definieren, um eine zielgerichtete Umsetzung zu ermöglichen.[43]

3.3.2 Risiken und Schwächen

Eine der wichtigesten Stärken des NIST AI RMF ist das sozio-technische Risikoverständnis, welches einem ganzheitlichen Ansatz zur Identifizierung und Bewertung von Risiken dient. Es werden Technik, Organisation, Prozesse und der Kontext der Anwendung berücksichtigt, um ein umfassendes Bild der Risiken zu erhalten. Mithilfe dieses Ansatzes, sind nicht nur bessere Entscheidungen zu treffen, der Einsatz von KI-Technologien wird dadurch auch sicherer,

[40] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.
[41] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.
[42] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.
[43] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.

fairer, erklärbarer und bezieht Grundrechte mit ein.[44]
Die Vorgehensweise des Modells mit den vier Kernfunktionen GOVERN, MAP, MEASURE und MONITOR ermöglicht eine nachvollziehbare und systematische Herangehensweise an das Management von KI-Risiken und die vorhandenen Tabellen erleichtern die Operative Umsetzung.[45]
Um Vertrauen in KI-Systeme zu schaffen und eine gemeinsame Grundlage über die unterschiedlichen Disziplinen, wie etwa Recht, Ethik, Technik und Management zu schaffen, dienen die sieben Eigenschaften vertrauenswürdiger KI als Leitlinien, die für alle Stakeholder gleich sind.[46]
Nicht nur ist das AI RMF ein freiwilliges Rahmenwerk, es kann auch entsprechend in bestehende Management- und Governance-Strukturen integriert werden und bietet mit dem MEASURE-Element eine Quantifizierung von Risiken und Maßnahmen, die eine messbare Verbesserung der KI-Governance ermöglichen.[47]
Ein weiterer Vorteil des AI RMF ist die regelmäßige Aktualisierung des Playbooks, welches die neuesten Entwicklungen und Best Practices im Bereich der KI-Governance berücksichtigt und somit eine kontinuierliche Verbesserung der Rahmenbedingungen für den Einsatz von KI-Technologien ermöglicht und die Verwendung von Best Practices fördert.[48]

[44] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.
[45] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.
[46] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.
[47] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.
[48] **nationalinstituteofstandardsandtechnologyAIRiskManagement2023**.

4 Vergleich und Bewertung (Matrix)

Ziel dieses Kapitels ist es, die fünf zuvor eingeführten Ansätze (ISOIEC 42001, EU AI Act, NIST AI RMF, Multilevel Framework, Hourglass Model) entlang eines einheitlichen Kriterienkatalogs systematisch zu vergleichen. Die Bewertung erfolgt transparent, nachverfolgbar und mit Quellenbezug zu Kapitel 3 sowie Interviewaussagen. Ergebnis sind eine priorisierte Auswahlempfehlung und Szenarien, in denen spezifische Modelle besondere Stärken aufweisen.

4.1 Bewertungslogik und Datengrundlage

Als Datengrundlage dienen die fünf zuvor beschriebenen Modelle aus Kapitel 3, deren Stärken und Schwächen und Interview-Insights (Anhang A). Die Bewertung erfolgt anhand des folgenden Kriterienkatalogs, dabei wird pro Modell je Kriterium ein Wert von 1 (schwach) bis 5 (stark) vergeben, inklusive knapper Begründung und Quellenangabe. Im Anschluss an die Bewertung wird ein Gesamtwert (gewichtetes Mittel) gebildet und ggf. Sensitivitäts-Checks durchgeführt.

4.2 Kriterienkatalog

Der Kriterienkatalog umfasst drei Dimensionen mit insgesamt zwölf Kriterien (K1–K12):

4.2.0.1 Regulatorische/strategische Anforderungen

K1 **Verbindlichkeit & Durchsetzbarkeit:** Existenz und Wirksamkeit verbindlicher Regeln, Eskalations- und Sanktionsmechanismen (Policies, Freigaben, Stop-Kriterien). Rating 1–5.

K2 **Regulatorische Passung (EU/Branche):** Anschlussfähigkeit an EU-/sektorale Vorgaben und Zukunftsfähigkeit (Standardisierung, Codes of Practice). Rating 1–5.

K3 **Strategische Steuerbarkeit:** Klarheit von Zielbildern, Risikotoleranzen, Rollen/Ownern, Gremien und Entscheidungstoren. Rating 1–5.

4.2.0.2 Operative Umsetzbarkeit

K4 **Lebenszyklus-Management:** Abdeckung von Scoping, Entwicklung/Deployment, Betrieb/Monitoring und Außerbetriebnahme. Rating 1–5.

K5 **Prüfbarkeit/Auditierbarkeit:** Nachvollziehbarkeit von Entscheidungen, Modellen, Daten und Freigaben (Logs, Doku, Artefakte, Audits). Rating 1–5.

K6 **Mess- & Metrikreife:** Verfügbarkeit/Eignung von Metriken und Tests (Robustheit, Bias/Fairness, Erklärbarkeit, Sicherheit/Privacy). Rating 1–5.

K7 **Skalierbarkeit & Integration:** Anschluss an bestehende Systeme/Prozesse (z. B. ISO/ISMS, internes Kontrollsystem, MLOps). Rating 1–5.

K8 **Ressourcen & Komplexität:** Implementierungs- und Betriebslast (Zeit, Personal, Budget), insbesondere KMU-Tauglichkeit. Rating 1–5.

4.2.0.3 Wert- & Stakeholderbezug

K9 **Grundrechts-/Ethiknähe & Betroffenenfokus:** Fairness, Nichtdiskriminierung, Transparenz, Contestability. Rating 1–5.

K10 **Stakeholder- & Kontextsensitivität:** Einbindung relevanter Stakeholder (z. B. DSB, CISO, Betriebsrat), Umgang mit kulturellen/organisationalen Unterschieden. Rating 1–5.

K11 **GPAI-/Ökosystem-Tauglichkeit:** Umgang mit Anbieter-/Lieferkettenanforderungen (Model Cards, Datenherkunft/IP, Kennzeichnung synthetischer Inhalte, Downstream-Hinweise). Rating 1–5.

K12 **Reifegrad & Praxisbelege:** Evidenzen aus Praxis/Piloten, Lessons Learned, Anschluss an Standardisierung. Rating 1–5.

4.2.0.4 Skalenanker (für konsistente Bewertungen) *Generische Anker* (für alle Kriterien, domänenspezifisch zu präzisieren): 1=*rudimentär/uneinheitlich*; 3=*teilweise vorhanden, Lücken erkennbar*; 5=*systematisch etabliert, evidenzgestützt, auditfähig*. Bei Bedarf werden pro Kriterium exemplarische Anker im Bewertungsdokument ergänzt (z. B. für K4: 5=*Lifecycle inkl. Drift-/Incident-Management mit KPIs*).

4.3 Scoring- und Gewichtungsschema

Die Bewertung erfolgt auf einer Skala von 1 bis 5. Als *Baseline* werden folgende Gewichte vorgeschlagen: *Regulatorisch/strategisch* 40 % (K1–K3), *Operativ* 40 % (K4–K8), *Wert/Stakeholder* 20 % (K9–K12). Die Gewichte werden szenariobasiert angepasst (vgl. 4.5).

4.4 Methodisches Vorgehen: Qualitative Experteninterviews

Zur empirischen Fundierung wurden halbstrukturierte, modell-agnostische Experteninterviews mit zentralen Stakeholdern (CIO, CISO, DSB, ggf. Compliance/HR) im eigenen Unternehmenskontext geführt. Ziel war es, Anforderungen, Risiken, Praktiken und Lücken im Umgang mit KI herauszuarbeiten, ohne Vorkenntnisse spezifischer Modelle zu unterstellen. Die Gespräche wurden per Microsoft Teams geführt und mit Zustimmung transkribiert; die Auswertung erfolgte mittels qualitativer Inhaltsanalyse (deduktive Codes: K1–K12; induktive Zusatzcodes). Aussagen werden anonymisiert als Interviewcodes referenziert (z. B. *I-CISO-14.08*).

4.4.0.1 Einbindung in die Bewertung Interviewaussagen dienen als Evidenz zur Justierung der Literatur-baseline:

- *Score-Anpassung:* Konsistente Interviewbefunde (≥2 Quellen) heben/senken den Basisscore um ± 1 Punkt; Begründung mit Interviewcodes.
- *Confidence-Flag:* Pro Kriterium wird die Evidenzlage als *hoch/mittel/niedrig* markiert (Triangulation: Literatur, Interviews, interne Artefakte).
- *Dokumentation:* Jede Score-Zelle enthält 1–2 Begründungssätze (Kapitelstelle/Interviewcode).

4.5 Sensitivitäts- und Szenarioanalyse

Zur Prüfung der Robustheit werden Gewichte szenariobasiert variiert: (A) *Streng reguliertes Umfeld* (+10 % auf K1/K2, −10 % verteilt); (B) *KMU/Lean Setup* (+10 % auf K8/K7); (C) *GPAI-intensiver Einsatz* (+10 % auf K11/K5). Verändert sich die Rangfolge der Modelle, wird dies berichtet und kurz begründet.

4.6 Darstellung der Ergebnisse

Die Resultate werden als Matrix (Zeilen=Modelle, Spalten=K1–K12) mit Farbskala (1–5) dargestellt; pro Zelle eine Kurzbegründung mit Kapitel-/Interviewverweis. Ergänzend werden Radar-Profile je Modell und ein Balkendiagramm der gewichteten Gesamtscores gezeigt. Ein kurzes Narrativ fasst die Stärken/Schwächen je Modell zusammen und leitet zu Kapitel 5 über.

5 Reflexion

6 Empfehlungen für die Gestaltung von AI-Governance

Literaturverzeichnis

Batool, Amna, Didar Zowghi und Muneera Bano (18. Dez. 2023). *Responsible AI Governance: A Systematic Literature Review*. DOI: 10.48550/arXiv.2401.10896. arXiv: 2401.10896 [cs]. URL: http://arxiv.org/abs/2401.10896 (besucht am 01. 06. 2025). Vorveröffentlichung.

Choung, Hyesun, John Seberger und Prabu David (9. Sep. 2024). *(PDF) A Multi-level Framework for AI Governance*. ResearchGate. DOI: 10.48550/arXiv.2307.03198. URL: https://www.researchgate.net/publication/372234650_A_multilevel_framework_for_AI_governance (besucht am 01. 06. 2025).

Comission, European (2025). *Ethics Guidelines for Trustworthy AI | Shaping Europe's Digital Future*. URL: https://digital-strategy.ec.europa.eu/en/library/ethics-guidelines-trustworthy-ai (besucht am 13. 06. 2025).

ISO (2025). *ISO/IEC 42001:2023(En), Information Technology — Artificial Intelligence — Management System*. URL: https://www.iso.org/obp/ui/en/#iso:std:iso-iec:42001:ed-1:v1:en (besucht am 13. 06. 2025).

Khatri, Vijay und Carol V. Brown (Jan. 2010). „Designing Data Governance". In: *Communications of the ACM* 53.1, S. 148–152. ISSN: 0001-0782, 1557-7317. DOI: 10.1145/1629175.1629210. URL: https://dl.acm.org/doi/10.1145/1629175.1629210 (besucht am 16. 08. 2025).

Kim, Byeong-Je u. a. (2025). „AI Governance in the Context of the EU AI Act: A Bibliometric and Literature Review Approach". In.

Mäntymäki, Matti u. a. (30. Juli 2025). *(PDF) Putting AI Ethics into Practice: The Hourglass Model of Organizational AI Governance*. ResearchGate. DOI: 10.48550/arXiv.2206.00335. URL: https://www.researchgate.net/publication/361023169_Putting_AI_Ethics_into_Practice_The_Hourglass_Model_of_Organizational_AI_Governance (besucht am 01. 06. 2025).

National Institute of Standards and Technology, U.S. Department of Commerce (2025). *AI Risk Management Framework*. URL: https://www.nist.gov/itl/ai-risk-management-framework (besucht am 13. 06. 2025).

Rai, Arun, Panos Constantinides und Saonee Sarker (6. Feb. 2019). „Next-Generation Digital Platforms: Toward Human-AI Hybrids". In: *MIS Quarterly* Volume 43 (Issue 1), S. iii–X. URL: https://www.researchgate.net/publication/330909988_Next-Generation_Digital_Platforms_Toward_Human-AI_Hybrids (besucht am 16. 08. 2025).

Weill, Peter David und Jeanne W. Ross (1. Juni 2004). *IT Governance: How Top Performers Manage IT Decision Rights for Superior Results | MIT CISR*. ISBN: 978-1-59139-253-8. URL: https://cisr.mit.edu/publication/it-governance-how-top-performers-manage-it-decision-rights-superior-results (besucht am 16. 08. 2025).

Appendix

A Interviewleitfaden

A.1 Einleitung

„Vielen Dank, dass Sie sich Zeit für dieses Interview genommen haben. Ziel ist es, Ihre Perspektive auf die Governance von Künstlicher Intelligenz im Unternehmen zu verstehen. Die Ergebnisse werden anonymisiert und ausschließlich im Rahmen meiner wissenschaftlichen Seminararbeit verwendet. Das Interview dauert ca. 30–45 Minuten. Ich würde gerne das Gespräch mitschneiden bzw. das Teams-Transkript verwenden – ist das für Sie in Ordnung?“

- Block A - Einstieg & Rollenbezug
    1. Wie sieht ihre aktuelle Rolle und Verantwortung im Unternehmen aus?
    2. Inwiefern haben Sie derzeit Berührungspunkte mit dem Thema Künstliche Intelligenz?
    3. Welche Entwicklungen oder Herausforderungen beobachten Sie im Unternehmen oder Ihrer Funktion im Kontext von KI?
- Block B - Ist-Zustand & Wahrnehmung
    1. Nennen Sie 2–3 konkrete KI-Anwendungsfälle (Zweck, Nutzer:innen, Daten).
    2. Wie werden diese initiiert, freigegeben, betrieben (Gremien, Policies, Freigaben, Monitoring)?
    3. Was läuft gut – und wo hakt es typischerweise?
- Block C - Anforderungen & Governance-Bedarf
    1. Was sind aus Ihrer Sicht die wichtigsten Anforderungen an eine gute Governance von KI?
    2. Welche Mindestprozesse/Entscheidungstore brauchen wir (vor Start, vor Go-Live, im Betrieb)?
    3. Welche Nachweise/Metriken/Dokumente bräuchten Sie für ein „Go“?
    4. Wer sollte aus Ihrer Sicht eingebunden sein (z.B. Fachbereichte, IT, Datenschutz, Geschäftsführung)?
- Block D - Risiken & Herausforderungen
    1. Welche Risiken sehen Sie im Zusammenhang mit KI aus Ihrer fachlichen Perspektive?

2. Wo sehen Sie potenzielle Zielkonflikte (z.B. zwischen Datenschutz, Security und Innovationsfähigkeit)?
3. Was müsste vermieden werden, damit eine Governance-Struktur tatsächlich funktioniert?

- Block E - Lieferkette & GPAI
  1. Wie gehen Sie mit Anbieterdokumentation (Model Cards, Datenherkunft, IP) um?
  2. Was brauchen Sie von Anbietern/IT/Prozessverantwortlichen, um Entscheidungen treffen zu können?
  3. Erfahrungen mit Generative-AI-Tools: Kennzeichnung, Rechte, Informationspflichten, Vertragsklauseln?
- Block F - Ressourcen, Kompetenzen & Kultur
  1. Wo fehlen Ressourcen/Kompetenzen (z. B. Metriken, Tooling, Schulung, Ops)?
  2. Welche Schulungen/Guides/Checklisten würden helfen?
  3. Was sollte vermeidbar sein, damit Governance nicht blockiert?
- Rollenspezifische Vertiefung
  - Für CIO/Head of IT
    * Wie sollte das Zusammenspiel zwischen IT, Fachbereichen und Governance bei KI aussehen?
    * Wo sehen Sie die Rolle der IT im Rahmen eines AI-Governance-Modells?
  - Für CISO/IT-Security
    * Welche spezifischen Bedrohungen oder Schwachstellen im Kontext von KI sehen Sie aus Security-Sicht?
    * Gibt es technische Mindestanforderungen, die erfüllt sein müssen, bevor KI-Lösungen eingeführt werden?
  - Für Datenschutzbauftragte
    * Welche datenschutzrechtlichen Herausforderungen sehen Sie bei KI-Anwendungen?
    * Gibt es aus Ihrer Sicht Fallstricke bei der Bewertung von Transparenz, Zweckbindung oder Datenminimierung?
  - Für Compliance / HR (optional)

    * Welche Anforderungen entstehen aus Sicht von Unternehmensrichtlinien, Ethik oder Personalentwicklung im Umgang mit KI?

- Abschlussfragen
  - Gibt es noch Aspekte, die Sie für besonders relevant halten, die wir noch nicht angesprochen haben?
  - Dürfte ich Sie ggf. bei Rückfragen im späteren Verlauf nochmal kontaktieren?

B Interview mit Leiter Controlling

Im folgenden ist das Transkript des Interviews mit der Leitung des Controllings der SARIA in Deutschland. Etwaige Zahlen und Namen wurden im Nachgang zensiert oder angepasst, dass keine Schlüsse zu realen Personen oder Informationen möglich sind.

◀ **Leitung Controlling** Hi Nick

▶ **Nick Stelzer** Hallo

◀ Sorry, ich war grad noch mit deinen Kollegen im Gespräch.

▶ Kein Thema. Ich hab einfach mal die Transkription gestartet, um das ganze als Transkript mitzunehmen, dass ich es für die Seminararbeit verwenden kann und es auch nochmal schriftlich zum nachlesen habe. Ansonsten schreibe ich natürlich mit, nur dass du da Bescheid weißt.

◀ Ok, alles klar.

▶ Ich möchte dich einmal zum gesamten Thema abholen. In meinem Master muss ich eine Seminararbeit schreiben. Ich habe damit auch schon angefangen. Bisher ist die Seminararbeit sehr theorielastig und ich würde aber gerne irgendwie ein bisschen Praxis mit einbringen. Das Thema ist Kalkulation und Abrechnung von IT-Services.
Wir rechnen aber noch nicht unbedingt in IT Services ab ja bisher, sondern eher unsere IT-Kosten. Und da würde ich gerne eben diesen Weg auch zeigen. Wie können wir von unserem aktuellen Stand dahin kommen, dass wir eben diese IT Services entsprechend abrechnen können, das ist so die Idee dahinter und hab ich gesagt, dann frag ich einfach mal dich.
Wie das Ganze gerade aktuell läuft, wie das Ganze aussieht und du mir da weiterhelfen kannst, ansonsten vielleicht jemand aus deinem Team, das ist ja gar kein Thema. Um dann eben auch zu schauen OK können wir da überhaupt Änderungen vornehmen aktuell oder wie das überhaupt oder ist das Ganze eher starr aufgebaut gerade aber erst mal geht es darum, überhaupt diesen ist Prozess aufzunehmen.
Wie machen wir es aktuell? Was haben wir aktuell da? Darum geht es mir erstmal.

◀ OK ja, da machen wir doch einmal die Reise also grundsätzlich fängt ja alles irgendwo an mit einer mit einer Planung. Im Rahmen des Budgets für nächstes Jahr. Haben wir jetzt ja auch gerade abgeschlossen für 2025.

Da setze ich mich mit den einzelnen Bereichsleitern zusammen und sag hey, wir planen jetzt deine Kostenstellen oder eure Kostenstellen. Was fällt da an an Kosten?
Seien es jetzt Lizenzkosten, seien es Mitarbeiter. Dann Hardware, alles was gekauft wird oder extern bezogen wird, ist ja sowohl Mitarbeiter als auch dann an anderen Leistungen und das planen wir ja nach bestimmten Kostenarten auf den jeweiligen Kostenstellen. Sodass wir nachher ein Gesamtbudget kriegen. Was dann? Der Bereich oder der jeweilige Abteilungsleiter beschreibt was er gedenkt auszugeben. Das geht natürlich auch irgendwo weiter nach oben, also erfolgt ja noch eine Freigabe. Also das heißt von mir kriegt nachher der Vorstand auch eine Übersicht, was in seinen administrativen Bereichen welche Kosten fallen an im Vergleich auch zum Vorjahr.
Dann müssen sich die die Bereichsleiter oder Abteilungsleiter auch noch mal irgendwo verantworten und sagen so hey, ich plane mit 20% höheren Kosten, weil ich habe jetzt Projekt A, B und C muss ich noch machen und dementsprechend erhöht das mein Budget für nächstes Jahr. Dementsprechend erfolgt dann eine Freigabe oder halt eine Kürzung. Es wird dann wieder was gestrichen, was dann nachher irgendwo ggf. zu irgendwelchen Maßnahmen führen muss. Da sagte er dann mache ich das Projekt nicht oder kann ich es vielleicht auch als günstigere Alternative durchführen? Und irgendwie ähnliche Ergebnisse erzielen genau das ist sozusagen erstmal der erste Prozess.
Ich kann ja mal einmal damit eine Idee kriegst eine Planung im Detail zeigen Genau mal gucken, so sieht das jetzt aus, du hast jetzt hier die Spaltköpfe dann das ist jetzt die Kostenstelle der IT. Was ist angelaufen Budget 24 dann? Was ist Januar bis Juli? Bereits an Kosten aufgelaufen wir machen nicht nur ein Budget, sondern wir machen auch unterjährig mal einen Forecast. Also hier mussten dann Ende Juli die Abteilungsleiter noch mal planen wieviel gebe ich eigentlich bis zum Jahresende aus? Und dann nochmal das Budget 25 dann siehst du halt hier die abweichung budget 25 gegen 23 budget, 25 gegen 24 und budget, 25 gegen forecast. Also das ist eigentlich das aktuellste hier die letzte Zeile so und dann haben wir hier in den Zeilen die verschiedenen Kostenartengruppen, das kann man halt aufklappen, dass man halt immer weiter ins Detail gehen kann. Dann siehst du halt hier die Kostenarten Gruppen zum Beispiel Gehälter. Also Aufbau von Mitarbeiterm nicht nur Gehaltsanpassungen, auch von Mitarbeitern. Ich hab hier meine ja Sozialversicherung ne Sozialleistung drin, dann eigentlich das nächste größere Interessante sind dann hier wenn ich hier reinklicke.

Einmal meine ganzen IT kosten hier wir haben IT Data Processing Consulting. Da läuft alles rein, was hier zum Beispiel Software as a Service ist also die ganzen monatlichen subscription fees. Beratungsleistung von externen Hardware was alles nicht aktiviert wird. Peripheriegeräte wenn ich jetzt sage, ich kaufe jetzt irgendwie 100 Tastaturen, die würden jetzt auch hier reinlaufen.
Dann habe ich hier meine Lizenzen. Dass sind dann tatsächlich die Lizenzen, die ich kaufe und dann auch die, die habe ich dann hier auf dieser Linie drin. Das sind eigentlich die großen Positionen hier hab ich noch ein bisschen eher Reisekosten.
Genau also es gibt halt bei der Anlage der Konten und es gibt halt für unsere Konten gibt es ne ja so zusagen Buchungsvorlagen Also was muss wohin gebucht werden? Da gibt's natürlich erstmal handelsrechtliche Notwendigkeiten, dass sich nach Handelsrecht das und das differenzieren muss für meine Bilanzierung. Dann gibt es teilweise auch dann irgendwo interne Notwendigkeiten oder Interessen. Das heißt, ich möchte im Controlling das und das auswerten, also ich muss ich bestimmten Sachverhalt will ich immer auf ein Konto buchen. Das ich dann mein Konto ist halt für mich immer eine Klammer dann sehe ich sofort alles was zu einem Sachverhalt gehört. Also was ist das für eine Sachleistung, die ich einkaufe? Hey und das habe ich auch hier und da schon mal mit dem IT-Leister diskutiert. Zum Beispiel diese Position, die ist halt relativ groß, ne?

► Ja, die ist sehr groß.

◄ Da ist viel drin. Genau da ist ja viel drin, ja. Für für Handelsrechtlich, sagen die ist, ist Bilanzierung, sagt da mit zum Verfeinern. Da haben wir kein Problem, da kann der Vertriebsprüfer der Wirtschaftsprüfer alle, die uns hier prüfen, die denen ist das in Ordnung, aber reicht ja trotzdem nicht, wenn wir irgendwie dazu Interesse kommen. Wir wollen uns intern steuern, müsste man halt das Aufteilen, da müsste man neue Konten anlegen und danach natürlich sagen was gehört auf welches Konto, dass das auch dann richtig gebucht wird. Hälfte nicht finde ich ganz viele Konten, habe aber die Kreditoren oder die Leute, die dann Rechnungen freigeben, dass trotzdem irgendwo hin packen.
Weil das ist immer die Gefahr umso differenzierter du wirst und wie die Leute ihre konnten nicht treffen beim Buchen und du wilst nachher das Konto auswerten. Was ist darauf gebucht? Findest du deine Sachverhalte doch nicht wieder, die du dir wünscht? Also das ist dann umso genauer du wirst immer auch dann mit einer sehr hohen Buchungsqualität. Sollte

das verbunden sein, ne sonst hast du nichts davon. Genauso gut kannst du ja dann auch.
Wir haben es jetzt hier in der IT, weil wir gehen gleich drauf ein, wie wir verrechnen haben wir in der ganzen Gruppe haben wir nur eine Kostenstelle. Das heißt, alle Personen, die unterschiedliche Leistungen erfüllen, ne oder unterschiedliche Dienstleistungen erbringen, die sind alle zusammengefasst. Ne also unser Projektmanagement? Unsere Group BI ist hier drin, Governance, Data Security, die sind alle hier auf der auf der Kostenstelle und machen unterschiedliche Leistungen. Das heißt, wenn ich eigentlich auch meine Budgets pro ja Team oder so erfassen möchte, müsste ich eigentlich die Kostenstelle weiter differenzieren, was ich über Untergruppen mache. Entweder, dass ich dafür eigene Kostenstellen anlege, oder? Wir haben zum Beispiel die Möglichkeit, bei uns Arbeitsplätze anzulegen. Arbeitsplätze ist sozusagen ne Detaillierung der Kostenstelle ne also ne kleinere. So ne kleinere Kostenstelle wenn du sagst das geht auch und wenn du das machst, dann kann ich ja dann auch wieder alle Kosten, die damit verbunden sind mit einem Bereich mit einem Team wieder separat tracken. Ich hab dann n eindeutiges Kontierungselement im System und kann dann nachher auf Knopfdruck sagen, Mein IT Projektmanagement kostet in Summe hunderttausend Euro keine Ahnung im Monat im Jahr aber das kannst du dann auf Knopfdruck sozusagen ermitteln. Das ist ja erst mal wichtig, dass du die Strukturen im System schaffst, dass du diese Auswertung möglichst schnell erzielen kannst und nicht irgendwie erstmal dich für Wochen einschließen musst, damit du weißt, was eigentlich das kostet. Dagegen läuft natürlich irgendwann so ein bisschen der Datenschutz.

► Absolut.

◄ Wenn ich jetzt sage, ich erfasse jetzt, ich mache pro Mitarbeiter eine Kostenstelle und kann dann schön erfassen, was mir ein Mitarbeiter kostet. Wird dann irgendwann schwierig, also ist dann.

► Nee, das soll ja nicht das Ziel sein.

◄ Ja, aber das ist dann halt immer ne, wenn mehrere Leute das machen eine Sache machen ist das einfach möglich, wenn wenn eine Person eine bestimmte Leistung erbringt, dann wird es schwierig. Ne um halt irgendwie auch so n bisschen den Datenschutz zu gewährleisten, aber dann könntest du wenn du die Notwendigkeit hast.
Also kostenarten, also weiß was habe ich für Kosten? Kannst du das über die Kostenarten halt oder die die Konten weiter differenzieren? Oder wenn

du sagst, welcher Bereich erzeugt welche Kosten, dann kannst du dafür neue Kostenstellen anlegen oder andere Kontierungs-Elemente und dadurch kannst du es ja immer weiter differenzieren und das ist erstmal das A und o ne, Bevor du anders verrechnen möchtest, musst du auch erstmal anders die Kosten erfassen.

▶ Ja. Stimmt.

◀ Genau. Mhm so also jetzt ist aber so erfassen wir jetzt die Kosten der lokalen IT. Und im Rahmen der Geschäftsversorgung oder Managementfee verrechnen wir die Kosten weiter.

▶ Mhm passiert das monatlich?

◀ Wir wir ermitteln einmal im Mittel einmal ein ein Verrechnungssatz und und da wird im Jahr abgerechnet, also pro Monat abgerechnet, also Gesamtvolumen dann pro Jahr, aber immer mit gleichbleibenden Beträgen. Also wenn ich jetzt sage, ihr habt jetzt in der IT ca. 9.000.000€ kosten. Dann würde ich sagen hier berechnen. Dann rechnen wir jeden Monat 240.000€ ab. So jetzt ist die Frage wer kriegt die Kosten? Ne? Ja, und dann ist dann gibt es den Unterschied, ja, die lokale IT die wird ja nur innerhalb von Deutschland verrechnet an die Tochterunternehmen. Wo wir währenddessen halt die Group IT halt internationaler tätig ist, ne, das heißt wir haben auch unterschiedliche Verteilungsschlüssel. Hier ist es nur Deutschland für die Group IT ist es komplett alle Länder, die Halt in dem Scope der Group IT sind.
Oh. Und da muss ich sagen, da sind wir halt Sehr pauschal halt unterwegs. Wir verrechnen in Deutschland die IT kosten anhand von Usern, an Usern und wir würden berücksichtigt dabei ERP, Rechnungswesen und Windows User, das heißt ich lass mir eine Liste geben aus der IT wieviele User pro Gesellschaft vorhanden sind. So dann hab ich die Summe und dann teile ich immer Lizenzen von den Tochtergesellschaften durch die Gesamtlizenzen. Also für über alle Gesellschaften und dann kommt er nachher raus. Die Tochtergesellschaft A hat 20% der Lizenzen, also bekommen die 20% der Kosten von der von der IT.
Das machen wir mit allen Bereichen so ne also, das heißt alle allgemeinen Bereiche verwaltungsbereiche, sei es Einkauf, sei es HR sei es. Sei es Controlling. Dass man sich überlegt, ne, jeder macht seine Budgetplanung, lässt sie sich freigeben. Weil er des Sage ist entweder vom Financial Director oder CFO und dann überlegen wir uns was ist ein einigermaßen guter Verteilungsschlüssel um Diese Kosten zu allokieren. DU siehst hier

jetzt die ganzen Bereiche aus Deutschland. Jetzt bitte keinen Screenshot oder sowas machen, das sind streng vertrauliche Daten.

► Kein Thema, wird nicht gemacht.

◄ Hier hast du die Bereiche in der Verwaltungsgesellschaft und hier hast du die ganzen Gesellschaften so, dann hast du die Bilanzierung hat insgesamt jetzt Kosten von Millionen Euro. Dann wird jetzt geguckt und wir sagen halt, wir machen die Bilanzierung nach Berichtseinheiten. Berichtseinheiten sind bei uns die Profit Center, die wir melden müssen und umso mehr Profit Center eine Gesellschaft hat, umso grundsätzlich ist es aufwendiger und du musst genauer buchen. Du hast mehr Kostenstellen, die du buchen kannst, weil mehr Sachverhalte gebucht werden. Also teilen wir das hier nach, sozusagen nach Berichtseinheiten auf, genauso aus dem Controlling wird hier nach Berichtseinheiten aufgeteilt. Also das hier als Beispiel bei Tochtergesellschaft A sind es 11% der Berichtseinheiten, also kriegt diese 11% der Kosten von Bilanzierung und von Controlling. Forderungsmanagement machen wir nach Debitorischen Belegen also das heißt umso mehr Ausgangsrechnungen ich schreibe umso mehr Zahlungseingänge muss ich verbuchen, umso mehr Mahnungen oder Inkassovorgänge habe ich etc. Kreditoren nach kreditorischen Belegen, also wieviel Eingangsrechnungen bekomme ich, die ich verarbeiten muss, wo ich auch wieder zahlen muss? Faktura nach Debitorischen belegen ist aber auch nicht großartig unser Bereich, der so kostenintensiv ist. Vertragsverwaltung ist nach den Kunden wieviel Leistungsorte haben wir in den Gesellschaften, die gepflegt werden. Personalmanagement und Lohnbuchhaltung nach Mitarbeitern jeder Mitarbeiter kriegt eine Lohnabrechnung oder Gehaltsabrechnung.
Genau und dann hast du hier die IT. Nach den Usern, den Usern gesagt, zählen wir Rechnungwesen, ERP und Windows Accounts. Das heißt ich theoretisch, der ich habe jetzt, ich habe jetzt einen User für die Rechnungswesen Software und ich habe einen Windows User, also kriege ich 2 Lizenzen gezählt. Andere Gesellschaften, die theoretisch jetzt nur ein Fahrer haben, der jetzt da gar keinen Zugang hat, der wird gar nicht gezählt. Das ist alles so ein bisschen ungefähr unschärfer genau und so kommst du halt dann zu den Kosten.
IT kosten in Deutschland lokal gehen dann halt hier beispielhaft mit 200.000€ zu Tochtergesellschaft A und die werden dann halt monatlich abgerechnet. So, das ist jetzt so, wie wir es machen.

► Verstanden.

◀ Also es gibt ja jetzt mehrere Überlegungen erstmal grundsätzlich. Die Kosten entstehen im Unternehmen und wir gehören alle zu einem Konzern, das heißt jeden Euro, den ich mehr oder weniger verrechne. Also sei es jetzt ich schlag jetzt mach da jetzt noch 20% Aufschlag drin, weil ich jetzt auf einmal auf die Idee komme die Verwaltungsgesellschaft muss jetzt Gewinn machen. Also schlage ich auf die Kosten von der IT 20% Marge drauf so dann machen wir nachher Gewinn die Tochtergesellschaft A macht dafür Verlust.

Im Konzern ist das Nullsummenspiel, weil das ist immer wir schreiben uns ja im Konzern eine Rechnung und im Konzern wird nachher alles konsolidiert. Zusammengefasst in zu einem Ergebnis das muss man mal sagen eines Tages hier, wir haben gar kein Interesse aus der Gesichtspunkten hier irgendwie mehr Aufwand reinzustecken.

So das einzige, wo es halt Interesse ist, wenn zum Beispiel ne Steuerungsfunktion darüber habe, ne den quasi den operativen Bereichen klarzumachen, wo sie in der Verwaltung mit Aufwand produzieren und dann zu sagen: Hey, mach das nicht, dann haben wir weniger Aufwand, also müssen wir müssen wir auch keine weitere Person halt einstellen, also dass wenn man das schaffen kann halt zu sagen hier das und das ist halt Aufwandstreiber bei uns in der Verwaltung. Das danach zu verrechnen, dass du daraus eine Steuerung für die operativen Bereiche schaffst und zu sagen Okay, Nene, lass das mal.

Das gefährliche ist aber immer was passiert dann, Beispiel Recruiting? Wenn du zum Beispiel Recruiting nimmst halt, wenn du sagst das ist ja auch eine Serviceleistung, die kann man sehr gut bewerten dann sagst du hey, wir haben 10 Recruiter mal aus der Luft gegriffen. Ich muss meine Stelle bei einem Recuritingportal schalten, das kostet mich auch irgendwie 1000€ und ich schaffe halt im Jahr 500 Bewährungsprozesse zu begleiten, dann kannst du auch ganz schnell rechnen so was kostet mich eigentlich ein Bewerbungsprozess. So das dann kannst du das Rausrechnen und dann könnte man jetzt sagen so, ich rechne Personalmanagement nicht mehr nach pauschal nach Mitarbeitern ab, sondern wird das hier aus der Geschäftsversorgung rausnehmen und jedes Mal, wenn einer den Bedarf hat, sag ich möchte jemandem Recruiter und dann sagt du gehst dann als Service und sagst Okay, wir begleiten dich gerne das kostet halt in Summe 2000€, wenn wir dich dabei begleiten, so das wäre ideal, nur das was passiert dann wiederum was ist, wenn eine Steuerungsfunktion also erstmal kümmere dich besser um deine eigenen Mitarbeiter, anstatt dass sie gehen? Weil jemand Neues einzustellen, halt teuer ist, aber was aber auch passieren kann, ist dann zum Beispiel Tochterunternehmen B sagt

wenn ich da jetzt Anrufe in der Verwaltungsgesellschaft und denen sage ich, ihr sollt mir helfen, jemanden zu finden, Assistenten oder so, dann bin ich sofort 2000€ los. Ich gehe jetzt selber los, ich kann das besser, ich schreib mal bei ebay Kleinanzeigen schreibe ich stelle zu vergeben oder sonst was oder mach Flurfunk.
Und auf einmal sitzt das Recruiting da und nichts mehr zu tun und dann sagen sie nächstes Jahr ja, wir schaffen gar nicht 500 stellen im Jahr zu betreuen, sondern noch 250 weil sich so wenig Leute melden so. Dann kostet im nächsten Jahr kostet der Recruiting Prozess 4000€, weil sie nur noch die Hälfte der Stellen machen. Aber trotzdem noch das gleiche Personal vorhalten und dann kommen noch weniger auf die Idee zu sagen dann geh ich so hin mit dem Control ich sag 4000€ fürs Recruiting das kann ich besser selber so, dann sind es nächstes Jahr noch 125 stellen. Dann kostet es noch mal mehr also das ist halt dann wieder was was bedeutet das dann auf der anderen Seite? Ne wenn wenn die Leute dann trotzdem daraus ausbrechen können und was machen die daraus?
Und da hast du ja, dann ist es ja keine Steuerungsfunktion, sondern es ist ja es ist es führt ja zu nicht zum besseren Ergebnis, sondern zum schlechteren Ergebnis, obwohl es eigentlich gut gemeint hast.

► Das sollte ganz klar nicht das Ziel der Maßnahmen sein.

◄ Ja genau, aber so ist eigentlich so würden wir dann wir machen ne Planung? Wir ermitteln einen Verteilungsschlüssel. Wir können dann die Kosten Allokieren auf die Gesellschaften und dann schreiben wir den Gesellschaften monatlich eine Rechnung für die Leistung, die wir erbringen. Und da steht dann halt einmal eine Leistung drauf die kriegen, die Tochtergesellschaft A kriegt jetzt eine Rechnung einmal oder pro Monat? Und zwar hier den Betrag, ne die kriegen jetzt alles in Rechnung gestellt. Die 1.200.0000€ pro Jahr, das heißt, 100.000€ im Monat kriegen die in Rechnung gestellt. Zum Beispiel mit dem Geschäftsführer von Tochterunternehmen A da Unterhalt ich mich einmal drüber und so, das sind die Kosten. Kostenbereiche aber die die kriegen jetzt von uns nicht eine Rechnung jeden Monat, wo steht du zahlst 10.000€ für IT, 20.000€ für Personal, sondern das ist einmal ne Rechnung, die die dann einbuchen. So ist zumindestens jetzt genau und dann, was wir dann machen oder was dann die jeweiligen Bereichsleiter oder Abteilungsleiter Halt als Verantwortung haben sagen. Hey, du hast ein Budget freigegeben bekommen durch den Budgetprozess auch durch die Rücksprache mit dem CFO so jetzt ist dein Ziel, dass du innerhalb dieses Budgets halt arbeitest und sicherstellst, dass das Budget einhältst, also dass du nicht mehr ausgibst, als was wir ursprünglich mal freigege-

ben haben.
So und dafür gibt es dann von unserer Seite wir machen natürlich jeden Monat gibt es ein Monatsergebnis. Einen Monatsabschluss für jede Gesellschaft. Aber man kann sich dann auch jetzt aktuell, weil wir noch kein Data Warehouse haben, machen wir das noch manuell in Excel, aber dann mit Power BI haben. Wir haben wir hier so einen kleinen Bericht und den kannst du dann aufrufen. Ich bin jetzt mal warte, ich tue jetzt mal, ob ich der IT-Leiter bin. Jetzt bin ich in der in der lokalen Verwaltungsgesellschaft also lokalen IT. Jetzt kann ich hier also hier ist das per per Role-Level-Security ich bin jetzt so reingegangen ich sehe alles, aber wenn der IT-Leiter sich anmelden würde, würde er nur die Kostenstelle IT sehen. Sondern siehst du jetzt hier, das ist eigentlich ja n bisschen uninteressant, aber hier würdest du das Ergebnis, ne G und v Ergebnis auf auf Kostenstelle sehen n paar Sachen werden hier direkt sogar von der Kostenstelle in Umsatz gelegt. Ne also zum Beispiel, wenn die IT Lizenzen also vorher war das immer die ganzen Lizenzen des Schwesterunternehmens, also die Windows Lizenzen hat die Verwaltungsgesellschaft eingekauft und weiterverkauft damit natürlich. Dass es hier hier im Materialaufwand stehen hier die die Lizenzen und das ist und hier werden sie weiter verrechnet.

► Okay.

◄ In den Umsatzerlösen das ist in Summe sich auf der Kostenstelle auflöst. Und dann siehst du hier, was sie was pro Monat hier ausgegeben worden ist, ne in den einzelnen Kategorien kannst hier mal dann weiter reinklicken. Dann siehst du halt was für ein Gehälter gezahlt haben was, was wir jetzt hier, ich sag mal jetzt Materialaufwand genau hier Lizenzen erstmal eingebucht haben. Sonst hier bei den SP AS ist eigentlich noch interessant. Das haben wir hier ja meistens hier Kosten der allgemeinen Verwaltung, da ist viel da siehst du hier jeden Monat meine Netzwerk et cetera und hier gibt's dann noch so einen Link womit du das PDF hierzu aufrufen kannst.
Also das im besten Fall, dass jeder Kostenstellen Verantwortliche zu jederzeit wissen sollte, was bei ihm passiert und welche Kosten er erzeugt. Hier kannst den Monat angucken, ob jetzt jeder Monat irgendwie ausschlägt nach oben und nach unten oder du guckst dir das hier im Vergleich an das ist ja anders eigentlich dann interessant, ne wo stehe ich ne? Im Vergleich actual gegen Plan ich hab das Budget Millionen hab ich jetzt aktuell bis 10 und ausgegeben hab ich also ein bisschen Luft. Dann sieht kannst du ja, sie ist ja auch von einem Balken, wo kommen sie denn her sonst die be-

trieblichen Auffindungen? Da hier habe ich mehr ausgegeben. Die hab ich mir ausgegeben. Hier auch mehr, aber dafür hier weniger. So als so geht das Ganze sehr genau prüfen. Aber in Summe ist halt viel, also, dass du halt in deinem Budget bleibst, z.B. wenn ich Mitarbeiter einstellen will aber finde keine, dafür arbeite ich da mit Zeitarbeit oder arbeite doch eher mit Consultant der mehr das ein oder andere zuarbeitet. Dann habe ich halt weniger Personalkosten, dafür aber höhere Consultantskosten ist ja auch absolut nachvollziehbar und das ist ja auch dann Aufgabe des Bereichsleiters, da irgendwie zu steuern und zu gucken wie kann ich irgendwie die ganzen Aufgaben irgendwo bewältigen. Nicht nur dass nachher die IT schön funktioniert, sondern dass natürlich auch die Kosten, die das in dem Zusammenhang entstehen, auch irgendwo im Rahmen bleiben, weil ich glaube schöner, höher, weiter können wir immer, aber es muss ja im Rahmen bleiben.
Ja also, das ist eigentlich dann die Aufgabe, so dass sozusagen im Budget übrig zu bleiben und wir machen das jetzt aktuell sogar am Jahresende also wir rechnen immer nach Plan, nach Budget ab. Wir werden ja immer eine gewisse Abweichung haben. Zwischen ist und Plan, ne weil wir machen das Budget im September und das heißt ja bis dann das Jahr zu Ende ist im nächsten Jahr, da sind da halt auch mal eben 16, 17 Monate dazwischen Da kann immer viel passieren. Wir rechnen aber zum zumindestens jetzt nach aktuellen Stand rechnen wir nicht spitz ab, das heißt, wir gehen nicht hin am Jahresende und sagen was hatten wir geplant? Wieviel Kosten sind entstanden? Und verrechnen dann noch mal den Delta Betrag auf die Gesellschaft, sondern dann der Differenzbetrag bleibt dann was über. Das wäre das, was ich am Anfang gesagt haben, die linke Tasche, rechte Tasche also hat die internationale Verwaltungsgesellschaft mehr Geld ausgegeben? Dann oder die lokale Verwaltungsgesellschaft mehr Geld ausgegeben in der IT dann hat sie da einen Verlust gemacht War sie am Ende sparsamer, hat sie einen Gewinn gemacht. Leichten Gewinn gemacht ja, so und das ist ja halt in Summe ja
So funktioniert es. Nur das ist halt immer schwierig jetzt, wenn du bestimmte Projekte für bestimmte Bereiche machst, ne, wenn jetzt wenn du sagst du bietest ne IT an, IT support, den nutzen alle Gesellschaften irgendwo. Manche haben auch n bisschen mehr n paar weniger Probleme wenn ich jetzt aber hinkomme in einen in diese Projekt Projekte die wir machen. Viele Projekte also zum Beispiel die Tenant Migration in Spanien oder in Italien ist auch warum soll Deutschland dafür zahlen? Ne also könnte man jetzt so sagen, das ist da sind wir jetzt nicht im ersten Moment genauso gleichzeitig. Jetzt arbeiten die Kollegen hier aus der Group BI

aktuell sehr stark hier mit unserer Datenplattform in Deutschland. Warum soll halt Spanien, warum soll halt Italien dafür zahlen?
Das ist dann halt erst, wenn du, wenn du viel auf Projektbasis arbeitest, in einem Jahr nutzt, der eine was und im nächsten Jahr nutzt der andere was und rechnet das immer alle ab? Wird es halt irgendwann schwierig, ne und da sind so glaub ich aus meiner Sicht die ersten Punkte, die man sich an annehmen muss sozusagen große Projekte. Die zu identifizieren und die separat abzurechnen, dass man sagt hier oder dass man halt so eine Mischkalkulation kommt, dann sagt hier die Group die Group IT die macht Projekte und die hat halt auch Tagesgeschäft. Dann sagt man ja 40% ist halt irgendwie Tagesgeschäft oder einfach verteilzeit das heißt 40% der Kosten wären halt pauschal abgerechnet. Pauschal abgerechnet nach Verteilungsschlüssel und irgendwann sagt sie, aber alles andere sind ja, müssen ja Projekte sein mit Identifizierbarem nutzen für uns, dass man diese Projekte halt separat ermittelt. Die Group BI die bucht halt ihre Stunden oder fast Ihre Stunden ihren Aufwand, den Sie für uns haben, irgendwo in einem Tool und dann sagt er die haben nachher 1000 Stunden dafür gearbeitet. Stundensatz ist x und dann kriegt halt, dann müssen wir sagen OK, dann wird das Projekt, was sie gemacht haben an an Deutschland an, vielleicht auch an meine Kostenstelle, weil ich sie halt mit betreut habe dann verrechnet. Dann sagt ihr hier das ist die Rechnung für die Implementierung? Monthly Endclosing für Deutschland hier Controlling hier kriegst du die Rechnung und nächstes Jahr gehen die nach Spanien und machen da ein großes Projekt. Und dann habe ich nächstes Jahr gar keine Kosten für für die Group BI weil die ja was anderes macht.

► Ja. Das Ganze geht ja theoretisch für für IT Services halt im kleineren Sinne das funktioniert genauso ist halt theoretisch dann nicht ein großes Projekt oder mehrere Projekte sondern kleine ja, ich sag mal mini Projekte, sag ich mal. Je nachdem wie man IT Service definiert wo du Halt sagst OK, diese Anzahl wurde halt von dem und dem Bereich genutzt. Die könnte man theoretisch abbrechen dann.

◄ Ja. Genau also auf jeden Fall richtig, da musst du mal gucken was steht das? Welcher Aufwand entsteht dadurch? Ne das abzurechnen und hast du dadurch? Ja, aus meiner Sicht muss er immer gewisse Steuerungsfunktionen hinter sein, ne dass, dass die Leute sich hinterfragen.

► Absolut.

◄ Ich mache jetzt für jeden kleinen Mist ein Ticket auf oder fahre ich meinen Rechner runter und wieder hoch und danach ist es weg oder so?

► Genauso nicht, auch nicht unbedingt für für solche kleinen Sachen. Aber es gibt ja durchaus so Sachen wieso eher so n miniprojekt halt, die wir schon eher als Service definiert haben wie neue Niederlassung oder sowas, wo wir halt gesagt haben OK, es gibt halt die Standardsachen die du irgendwie brauchst für ne neue Niederlassung und das sind halt die Sachen die wir dann liefern würden. Dass, dass man so in die Richtung geht, also nicht ganz klein, das ist klar, das geht auch nicht auf Support zum Beispiel, das wird auch schwierig. Das wird wahrscheinlich weiterhin pauschal bleiben, das ist auch klar, aber so manche Sachen müssen halt dann genau definieren, eben auch im im Service-Katalog. Aber ich glaube, da gibt es durchaus ein paar Sachen, die man da ganz gut abgesehen von nur Lizenzen, zum Beispiel da irgendwie gut beim Abrechnen kann oder auch so Sachen wie beim Betrieb des des EAP Systems zum Beispiel, das sind auch so Sachen bei Changes oder sowas, die auch nicht unbedingt IT-Kosten sind, weil die jemand anderes vielleicht ne ne Änderung haben möchte.

◄ Ja, es muss halt irgendwie. Ich finde immer wichtig, dass es gewisse Unregelmäßigkeit hat. Ne also dass wenn wenn quasi jeder jeden Monat jede Gesellschaft eine Sache bei euch anfragt, wenn wir das alles gleich verteilt ist. Warum soll ich das denn warum soll ich das separat in Rechnung stellen? Aber wenn eine wenn es irgendwo n gewisses Ungleichgewicht gibt oder bestimmte Projekte, wo ich sag auf einmal ziehen die mir jetzt Ressourcen aus dem Team raus. Und dafür stehen die Ressourcen halt für andere Bereiche nicht zur Verfügung und wo dann leichter noch die Frage kommt die Tochtergesellschaft A macht große Sache mit euch? Und dann sagt einmal irgendwann eine Tochtergesellschaft B ihr ich brauch mal Hilfe von der IT und sagen Wir haben keine Zeit, wir machen gerade was für Tochtergesellschaft A. Dass man dann zu sagen sei ich Zahl auch für euch warum könnt ihr mir jetzt nicht helfen?
Ja klar das das das das ja oder als in der Technik ist das ja auch sehr stark, ne wenn wir große technische Abscheidung? Wenn die Projekte begleiten ne, wir stellen jetzt irgendwelche Produktionsprozesse rum, wir machen neues Produktionslayout, dann arbeiten die halt 3, 4, 5, 6 Monate nur an einem Projekt. Warum soll ich dann die Kosten für die Leute halt auf alle aufteilen? Dann müssen die Ihre Stunden erfassen hier ich arbeite gerade auf dem Projekt Lünen und dann kriegt nachher eine Rechnung für die Techniker oder die Ingenieure, die dann halt das halbe Jahr oder das Jahr das Projekt mit begleitet haben. Alle müssten das sont zahlen. So du musst halt natürlich dann auch die Mitarbeiter zu anhalten, also

Erzeugst, ja Bürokratieaufwand, Stundenerfassung etc. Wir wollen nicht im nächsten Moment alles tracken, ne?

▶ Nein, das funktioniert ja auch nicht, das ist auch klar, aber irgendwo muss man halt anfangen, auch weil du so halt auch in der IT so gar keine Übersicht hast, wer nutzt überhaupt was aktuell? Das ist ja alles nicht so gegeben.

◀ Mhm. Aber das musst du auch erstmal dokumentieren ne also auch nicht nur erstmal die, die du musst ja beides erfassen, einmal immer den Output, den ihr generiert ne also was haben wir geschafft? Aber auch gleichzeitig den Input ne, also welche Kosten sind dadurch entstanden? Ne also ich hab erst mal das reingesteckt in IT und das ist da rausgekommen und die beiden musst du ja ermitteln, damit du halt irgendwie auch n Verrechnungssatz haben kannst, den du dann auch sagen kannst. Hier jährlicher Report et cetera das stelle ich euch jetzt separat in Rechnung und nicht pauschal über die Geschäftsversorgung. Weil in Summe zahlen sie es ja alle, nur das führt ja vielleicht zu Verschiebungen, das ist auf einmal die Tochtergesellschaft A mehr oder weniger zahlt und dafür diese kann nie mehr oder weniger also ein bisschen mehr Gerechtigkeit.

▶ Genau das ist ja eigentlich auch so n bisschen das Ziel, weil ich glaube, dass das gerade auch ganz viel also zumindest ist ne Wahrnehmung, die wir halt intern haben, dass da so einige Gesellschaften gibt, die deutlich mehr Aufwand generieren als andere.

◀ Wer ist das denn?

▶ Tochtergesellschaft B, die ist da echt groß dabei mit Aufwand und die Tochtergesellschaft C, die auch mit den ganzen Mini-Niederlassungen, das ist auch echt anstrengend.

◀ Aber schön schön, dass wir beide ich ehrlich erfreut, mich gefreut ich hätte die gleichen beiden genannt.

▶ Ja, das sind das sind leider die beiden, wo das, wo das wirklich immer wieder auftritt, wo dann auch sagen OK ja, irgendwie passt das doch gar nicht manchmal so Vergleich deswegen da ein bisschen mehr Fairness auch reinzubringen, ist natürlich auch durch das Thema auch für die anderen die halt deutlich weniger. Genau.

◀ Die anderen sind ja auch teilweise relativ einfach, was brauchen die?

▶ Das läuft halt und dann wenn wenn halt mal der Rechner nicht geht, dann rufen sie an und dann klären wir das. Das ist nicht das Thema, bei den anderen sieht das anders aus. Wie gesagt ja, die einen mit ihren neuen Mini-Niedergelassen und da ist unser zuständige Kollege immer amverzweifeln jedes Mal wenn es wieder auftaucht, ohne dass er vorher Bescheid gewusst haben, das ist auch immer sehr anstrengend.

◀ Ja, brauchst du denn noch irgendwas von mir, oder jetzt reichen dir erstmal die Ausführungen?

▶ Ich glaub, das reicht mir erstmal. So muss man überlegen, was ich daraus daraus mache, das erstmal aufzuschreiben, wie es aktuell läuft, das glaub ich erstmal das erste Ziel und dann halt zu gucken OK was sagt die Theorie sonst noch? Wie ist irgendwie? Es gibt Tausende von Möglichkeiten, wie man das Ganze rechnen kann, da jeder, glaube ich, so ein bisschen selber irgendwo verewigt. Deswegen da mal zu schauen okay, was macht tatsächlich einfach Sinn, wo kann man da gut einsteigen und sich mal überlegen wie können wir da vielleicht auch ein Nutzen von ziehen?

◀ Mhm. Ja, also es, ich glaub der Nutzen bleibt bei uns, wenn es einigermaßen pragmatisch ist, ne also also wir fangen wir sind jetzt du musst ja irgendwie da das Thema einsteigen, oder mit der Zeit immer besser immer weiter optimieren. Weil sonst kriegst du Leute, die mitgenommen ne, das ist ja auch ein Change Prozess, wenn du jetzt auch immer das machst und sagst ich hab das jetzt ein theoretisches Modell. Das Haargenau das berechnet, aber dafür müssen sie die Voraussetzungen geschafft sein. Das wirst du nie einführen können, also irgendwann vor Frust.

▶ Aber ich denke es ist keine schlechte Idee, das als Zielbild irgendwo zu setzen, ne dass man sagt OK, da wollen wir vielleicht irgendwann hin, aber dann halt die Steps dahin langsam anzugehen. Das glaube ich ist auch eher so n so n Thema, wo man sagt OK, dass das große Ziel, wo wir vielleicht irgendwann in Jahren 10 Jahren weiß ich nicht sein wollen, aber die ersten Steps sind halt die die schwierigsten meistens auch. Aber auch die, die Halt am vorsichtigsten sein müssen.

◀ Ja genau würde erstmal, wenn der Laden erst mal sich bewegt, dann, dann musst du nur gucken, dass er in Bewegung bleibt, ja.

▶ Genau, wenn es einmal rollt ne, wenn der Stein rollt, dann dann geht das ja ich danke dir auf jeden Fall schon mal für die ganzen Ausführungen super interessant auch ich ich finde das Thema an sich ja super spannend. Also

das ganze Controllingthema ist sowieso. Auch im Studium schon immer spannend gewesen, aber auch sehr anstrengend. Leider muss ich doch zugeben. Aber genau dann kann ich da auch noch mal aufzeigen OK, so läuft es vielleicht gerade. Auch in dem Unternehmen mal Und dann? Und dann kann ich jetzt nur sagen ich habe zumindest mal auch noch mal mit jemandem gesprochen, der mir das auch sagt so läuft das ja.

◀ Ja also, ich kann dir ja dein Chef hat ja schon gesagt, du kannst Zugriff auf die Kostenstellen kriegen. Da hast du auf jeden Fall die Zahlen trotzdem außerhalb der Saria Welt nicht werden.

▶ Das klar, das ist, das ist klar, da zahlen wir keine genannt, auch keine Namen oder sonst irgendwas alles, das ist alles klar also der Name SARIA ja, der fällt, das ist klar, aber dann hörts halt auf also dann geht es halt um um Gesellschaften da drunter oder so, die dann halt nicht benannt sind, sondern Gesellschaft, ABC oder whatever, das ist dann alles anonymisiert, entsprechend auch wie gesagt keine Zahlen oder sonst.

◀ Ja, das ist das was ich dir auf jeden Fall sagen muss, dass du die Zahlen nicht so rausgeben darfst.

▶ Ja, ich versteh das absolut wie gesagt, ich bin da auch voll im Datenschutzbereich unterwegs und habe damit immer wieder Berührungspunkte. Bin absolut voll auf deiner Seite. Das muss entsprechend so gemacht werden, aber da bin ich auch immer hinterher. Mein Chef wird das Ganze sowieso noch mal querlesen. Das heißt also, wenn da noch irgendwas auffällt, dann fliegt das auch sofort wieder raus. Also das sollte eigentlich nicht der Fall sein.

◀ Ja, OK gut, ja, dann würd ich sagen dann viel Erfolg erstmal weiter beim Verfassen deiner Arbeit und wenn noch irgendwas ist dann einfach mal durchrufen oder noch mal Bescheid sagen.

▶ Dann meld ich mich. Mach ich alles klar, Dankeschön, dann noch einen schönen Montag.

◀ Gerne ciao.

▶ Bis dann

C Abbildungen

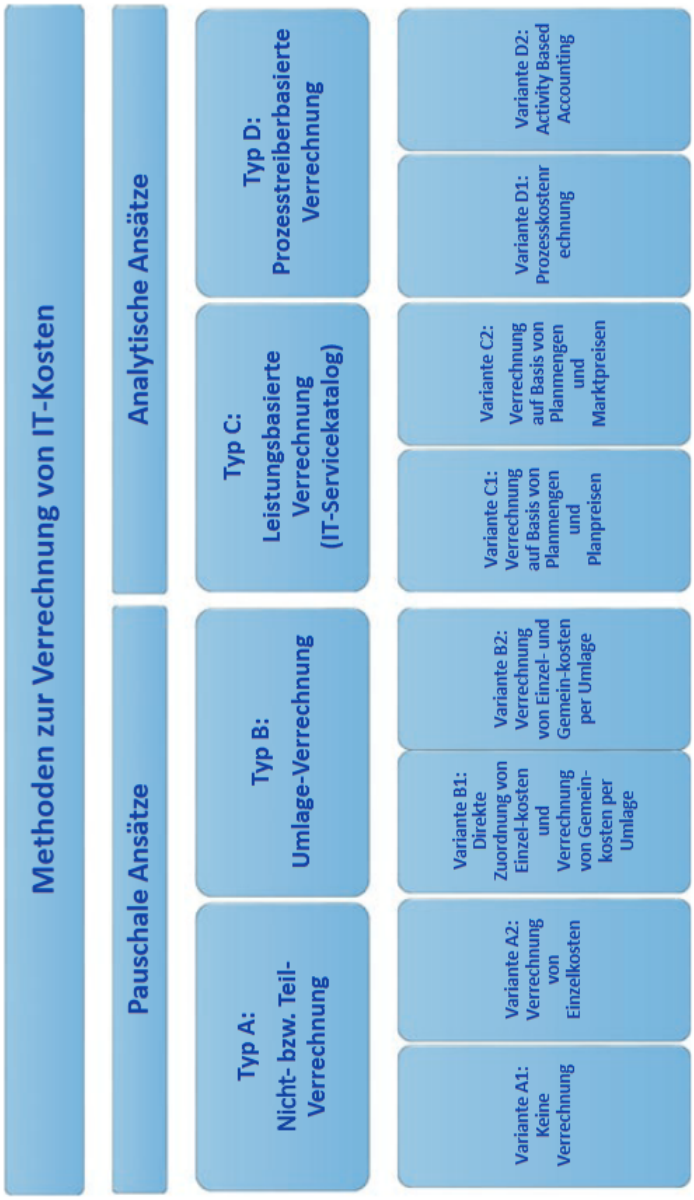

Abbildung 1: Methoden zur Verrechnung von IT-Kosten und -Leistungen[49]

[49] **gadatschITControllingITKostenUnd2021**.

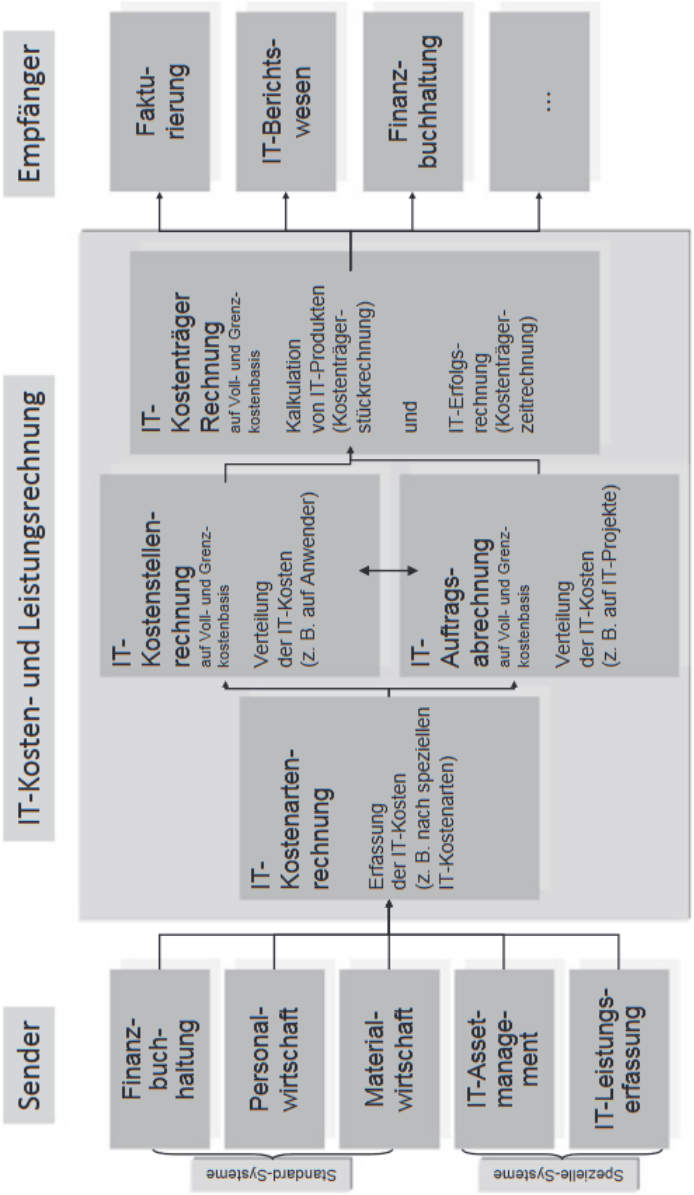

Abbildung 2: Struktur einer IT-Kosten- und Leistungsrechnung[50]

[50] **gadatschITControllingITKostenUnd2021**.

Nr.	Position	Bemerkung	Werte	Bemerkung
01	Hardwarekosten		12,50 Euro	600 Euro / 4 Jahre / 12 Monate
02	+ Materialgemeinkosten	% Zuschlag auf 01	1,25 Euro	10% von 12,50 Euro
03	**= Materialkosten**	**Summe 01 - 02**	**13,75 Euro**	
04	+ Lizenzen Standardapplikationen (Betriebssystem, Office u.a.)		8,33 Euro	Betriebssystem und Office 100 Euro + 300 Euro = 400 Euro / 4 Jahre / 12 Monate
05	+ Anschluss Netzwerk	Pauschale incl.	1,04 Euro	50 Euro / 4 Jahre / 12 Monate
06	+ Lizenzen Zusatzkomponenten		58,33 Euro	SAP 700 Euro / 12 Monate
07	+ Pauschale für IT-Service (Installation, Hotline, Fehlerkorrekturen, Softwareupdate)		30 Euro	30 Euro (bereits Monatswert)
08	**= Lizenzen und Service**	**Summe 04 - 07**	**97,70 Euro**	
09	**= IT-Produktkosten I**	**Summe 03 + 08**	**111,45 Euro**	
10	+ CIO-Umlage	% Zuschlag auf 09	22,29 Euro	20% von 111,45 Euro
11	**IT-Produktkosten II** (monatlicher Verrechnungssatz)	**Summe 09 + 10**	**133,74 Euro**	

Abbildung 3: Kalkulationsbeispiel eines IT-Arbeitsplatzes[51]

[51] **gadatschITControllingITKostenUnd2021**.

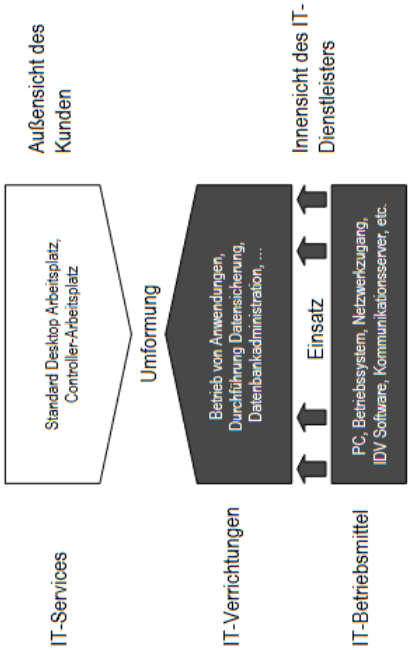

Abbildung 4: IT-Service als Ergebnis der Kombination von IT-Leistungen und IT-Ressourcen am Beispiel des IT-Service Arbeitsplatz[52]

[52] **teubnerITServiceManagementNeues2008**.

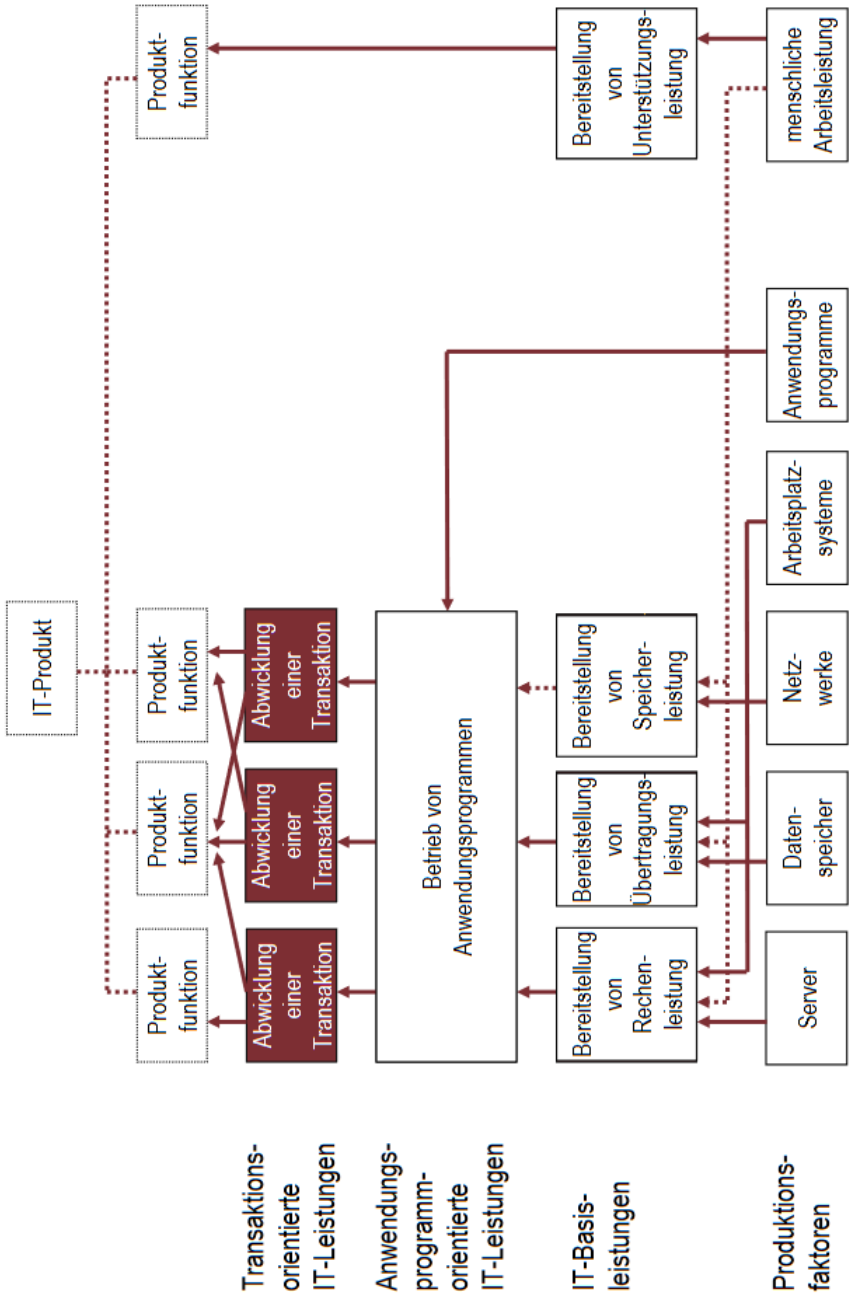

Abbildung 5: IT-Leistungen als Beiträge zu geschäftsorientierten IT-Services[53]

[53] **zarnekowProduktionsmanagementITDienstleistungen2007**.

Geschäft	IT-gestützte Abwicklung von Geschäftsprozessen (z.B. Rechnungserstellung), IT-Beitrag in End-Produkten des Unternehmens
Informationsressourcen	Information, Daten (z.B. Kundendaten, Intranetinhalte)
Anwendungssystem	Anwendungssystem (z.B. SAP-Modul)
	Anwendungssystemplattform (z.B. SAP-Server)
IK-Technische Infrastruktur	Endgerät (z.B. Desktop Arbeitsplatz = PC + EA-Geräte + Netzzugang etc.)
	Infrastruktursystem (z. B. LAN, WAN)
	Infrastrukturkomponente (z. B. Gateways, Rechner, Drucker)
Non IT Facilities	Facilities (z. B. Gebäude, Zugangssicherung, Notstromversorgung)

Abbildung 6: Wertschöpfungstiefe der Informationsinfrastruktur[54]

[54] **teubnerISSN14383985Print.**

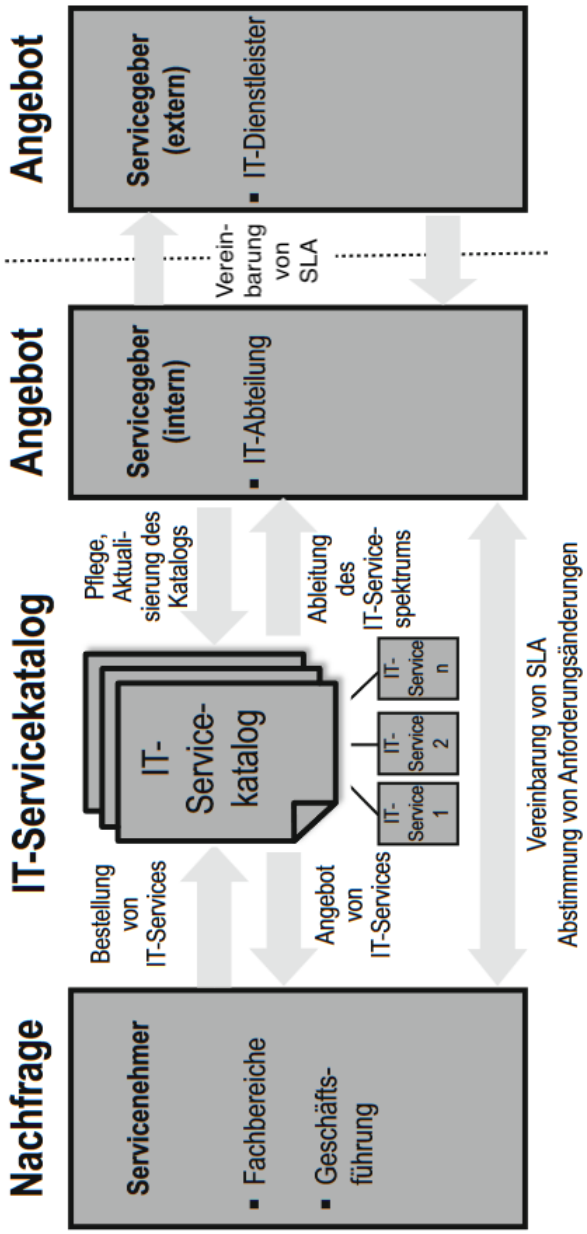

Abbildung 7: Akteure im IT-Serviceverhältnis[55]

[55] **rudolphHandlungsleitfadenITServicesUnd2008**.

Eidesstattliche Erklärung

Stelzer, Nick Ansgar

Name, Vorname // Name, First Name

Ich erkläre hiermit, dass ich meine Seminararbeit mit dem Titel

Governance von Künstlicher Intelligenz: Eine vergleichende Analyse bestehender Modelle zur Gestaltung unternehmensinterner KI-Steuerung

selbständig und ohne fremde Hilfe angefertigt habe, und dass ich alle von anderen Autoren wörtlich übernommenen Stellen wie auch die sich an die Gedankengänge anderer Autoren eng anlehnenden Ausführungen meiner Arbeit besonders gekennzeichnet und die Quellen zitiert habe.

Südkirchen, den 19. August 2025

Ort, Datum, Unterschrift // Place, Date, Signature